



UNIVERSIDAD ICESI

MAESTRIA EN INTELIGENCIA ARTIFICIAL APLICADA

**PROYECTO – AGENTES IA PARA GESTION DE
VULNERABILIDADES**

**Arquitectura EMCALI Cyber 2.0 Enterprise Hibrido
Plataforma Inteligente para Gestión Defensiva de
Vulnerabilidades mediante LLMs Locales, RAG, Agentes IA e
Inferencia Híbrida**

Presentado por:

**EDWIN PEREZ LOZANO
CRISTIAN CAMILO QUEBRADA
RUBEN DARIO SABOGAL U**

Para: Proyectos de innovación II

Cali, junio de 2026

Índice

Contenido

Resumen	14
Abstract	15
CAPÍTULO 1. INTRODUCCIÓN.....	16
1.1 Contexto Organizacional	16
1.2 Problema de Investigación.....	16
1.3 Justificación	16
1.4 Objetivo General.....	17
1.5 Objetivos Específicos	17
CAPÍTULO II - MARCO TEÓRICO Y ESTADO DEL ARTE.....	18
2.1 Vulnerabilidad	18
¿Qué es una Vulnerabilidad?.....	18
2.2 La ecuación del Riesgo	18
2.3 Tipos de Vulnerabilidades (Con Ejemplos).....	18
• Vulnerabilidades de Software (Código o Diseño).....	18
• Vulnerabilidades de Configuración.....	19
• Vulnerabilidades de Hardware.....	19
• Vulnerabilidades Humanas (El eslabón más débil).....	19
• Vulnerabilidades de Proceso o Procedimiento	19
Un Ejemplo Práctico e Integral.....	19
2.4 Sistema CVE (Common Vulnerabilities and Exposures).....	20
¿Cómo funciona la nomenclatura?	20
CVE – [Año de reporte] – [Número secuencial].....	20
2.5 CVSS (Common Vulnerability Scoring System)	21
¿Cómo se calcula la puntuación?	21
La Escala de Severidad CVSS (Versión 3.x / 4.0)	21
2.6 EPSS (Exploit Prediction Scoring System).....	22
¿Cómo se lee el EPSS?	22

2.7 CISA KEV (Known Exploited Vulnerabilities Catalog).....	23
¿Por qué tiene tanto impacto técnico?	23
Comparativa: ¿Cómo se complementan?	23
El flujo de decisión ideal (Chaining)	24
2.8 LLM (Large Language Model - Modelo de Lenguaje Grande)	24
2.9 Ollama	24
2.10 RAG Retrieval-Augmented Generation - Generación Aumentada por Recuperación	25
¿Cómo funciona el flujo de un sistema RAG?	25
El Ecosistema Completo: ¿Cómo se unen los tres?	25
2.11 MCP (Model Context Protocol)	26
¿Cómo funciona MCP?	26
2.12. LangGraph	26
Componentes clave de LangGraph:	26
La Sinergia: MCP + LangGraph + Ollama + RAG	27
2.13 LangChain	27
Los Componentes Clave de LangChain	27
• Modelos (Models & I/O).....	27
• Prompts (Prompt Templates)	28
• Cadenas (Chains / LCEL).....	28
Este es el corazón del framework. A través de LCEL (LangChain Expression Language), puedes encadenar componentes de forma limpia usando el operador pipe (<code> </code>).	28
<i>Ejemplo de una cadena básica: Template LLM OutputParser (Toma el prompt dinámico, lo pasa al modelo y luego formatea la respuesta en un JSON limpio).</i>	28
• Memoria (Memory).....	28
• Recuperadores (Retrieval)	28
• Agentes (Agents & Tools).....	28
• La Evolución: De LangChain a LangGraph	28
El Panorama Completo	29

2.14 Estado del Arte (2022-2026)	31
CAPÍTULO III - METODOLOGÍA Y DISEÑO DE LA SOLUCIÓN.....	34
3.1 Tipo de Investigación.....	34
.....	34
3.1.1 Investigación Aplicada.....	34
3.1.2 Enfoque Mixto	35
Componente Cuantitativo	35
Componente Cualitativo	35
3.1.3 Diseño Experimental	35
3.2 Arquitectura General de EMCALI Cyber 2.0 Híbrido Enterprise	35
3.2.1 Arquitectura por Capas	36
.....	36
3.2.2 Capa 1: Fuentes de Datos	37
Tenable : Plataforma líder en Vulnerability Management.	37
Qualys: Permite realizar: Escaneo de vulnerabilidades, Gestión de activos, Evaluación continua de riesgos.....	37
NVD (National Vulnerability Database): Base oficial mantenida por NIST.	37
CISA KEV: Catálogo de vulnerabilidades activamente explotadas.	37
3.2.2 Capa 2: Motor de Normalización (JSON Engine)	37
Funciones principales: Estandarización de datos, Eliminación de duplicados, Homologación de atributos, Conversión a un esquema común.	37
3.2.3 Capa 3: Motor de Inteligencia Artificial (LLM Engine)	38
3.2.4 Capa 4: Motor de Riesgo	38
3.2.5 Capa 5: Motor de Remediación.....	38
3.2.6 Capa 6: Dashboard Ejecutivo	38
3.3 Flujo Operacional y Topología Funcional	38
3.4 Arquitectura Híbrida de Inteligencia Artificial	39
Inferencia Local	39
Inferencia Cloud.....	40
Google Gemini	40

OpenAI	40
Mecanismo de Fallback Inteligente	40
3.5 Arquitectura RAG	40
Concepto : Retrieval Augmented Generation (RAG) combina recuperación de conocimiento con generación de lenguaje natural. Su objetivo es reducir alucinaciones y aumentar precisión.	40
Base Vectorial : Almacena representaciones matemáticas de documentos.	40
Embeddings: Los embeddings transforman texto en vectores numéricos. Permiten calcular similitud semántica.	40
Base de Conocimiento: Incluye: ISO 27001, NIST, MITRE ATT&CK, Guías de remediación, Procedimientos EMCALI.	40
Recuperación Contextual: Antes de responder: Se consulta la base vectorial, Se recuperan documentos relevantes, Se construye el contexto, El LLM genera la respuesta.	41
3.6 Modelo de Riesgo	41
Variable CVSS	41
Variable EPSS	41
Variable KEV	41
Criticidad del Activo	41
Importancia del Negocio	41
Fórmula Conceptual	41
3.7 Modelo de Amenazas	42
Spoofing : Suplantación de identidad.	42
Tampering: Manipulación de datos.	42
Repudiation: Negación de acciones realizadas.	42
Information Disclosure: Divulgación no autorizada.	42
Denial of Service (DoS) : Interrupción del servicio.	42
Elevation of Privilege: Escalamiento de privilegios.	42
CAPÍTULO IV - IMPLEMENTACIÓN Y PRUEBAS	43
4.1 Entorno Experimental	43
.....	43

4.1.1 Introducción.....	43
4.1.2 Plataforma Lenovo ThinkPad X230.....	43
Características	43
Justificación	44
Resultados observados	44
4.1.3 Plataforma Dell Precision T1650	44
Características	44
Justificación	44
Resultados	44
4.1.4 Plataforma HP Z600	45
Características	45
Justificación	45
Resultados	45
4.1.5 Evaluación de GPU	45
NVIDIA Quadro 2000	45
NVIDIA Quadro K4000	45
NVIDIA GTX 165	45
4.2 Herramientas Utilizadas	46
Python	46
Streamlit	46
Ollama	46
LangChain	46
Pandas	46
Plotly	46
SQLite	46
FAISS	46
ChromaDB	47
4.3 Arquitectura Interna de Componentes	47
4.4 Desarrollo de EMCALI Cyber 2.0	47

Dashboard : Módulo encargado de: Visualización ejecutiva, KPIs, Indicadores de riesgo, Tendencias.	47
Analyze : Núcleo analítico de IA.....	47
Risk : Motor de evaluación de riesgos.....	48
Remediate : Genera: Recomendaciones, Planes de acción, Estrategias de mitigación, Asistido mediante IA generativa.	48
Reports : Produce: Informes técnicos, Informes ejecutivos, Evidencias de auditoría. ...	48
RAG : Módulo de recuperación aumentada.....	48
Settings : Administra: Backends IA, Modelos, Parámetros, Timeouts, Configuración de GPU.....	48
4.5 Arquitectura RAG Implementada	48
4.6 Arquitectura de Despliegue.....	49
4.7 Flujo de Inferencia Híbrida.....	49
4.8 Topología funcional y módulos internos con ingesta de datos.....	50
4.9 Casos de Prueba	50
Caso de Prueba 1 : Análisis Individual de CVE	50
Caso de Prueba 2 : Análisis Masivo	50
Caso de Prueba 3 : Generación de Remediación	51
Caso de Prueba 4 : Fallback Local → Cloud	51
Caso de Prueba 5 : Evaluación del Módulo RAG	51
4.5 Métricas de Evaluación	51
Tiempo de Respuesta	51
Consumo de CPU	51
Consumo de RAM	51
Consumo de Tokens	52
Precisión	52
Consistencia	52
Costo Operativo	52
CAPÍTULO V - ANÁLISIS Y DISCUSIÓN DE RESULTADOS	53
5.1 Resultados Funcionales.....	53

5.1.1 Introducción.....	53
5.1.2 Reducción de Tiempos de Análisis.....	53
Resultado observado	53
Interpretación	54
5.1.3 Automatización del Proceso.....	54
Beneficios obtenidos : Reducción de errores humanos, Mayor velocidad operativa, Procesamiento continuo, Homogeneidad en los análisis.	54
5.1.4 Incremento de la Trazabilidad	54
Resultado	54
5.2 Resultados de Inteligencia Artificial.....	54
5.2.1 Comparación de Modelos LLM.....	54
Tabla 5.1 Comparación Experimental de Modelos	55
.....	55
Phi-3 Mini	55
Fortalezas : Bajo consumo, Excelente rendimiento en equipos modestos, Respuestas rápidas.	55
Debilidades : Menor profundidad contextual.	55
Aplicación recomendada: Análisis operativo diario.	55
Mistral 7B	55
Fortalezas : Excelente equilibrio entre precisión y consumo.	55
Debilidades: Requiere mayor capacidad computacional.	55
Aplicación recomendada: Procesamiento empresarial estándar.....	55
Llama 3.1 8B	55
Fortalezas: Mayor capacidad de razonamiento, Mejor interpretación contextual.	55
Debilidades: Mayor consumo de recursos.	55
Aplicación recomendada: Análisis complejos y generación de informes.....	55
5.2.2 Impacto del Uso de RAG	55
Resultado observado	56
Interpretación: La incorporación de conocimiento institucional convierte al modelo de lenguaje en un asistente especializado en ciberseguridad organizacional.	56

5.2.3 Evaluación del Fallback Inteligente	56
Resultado : La continuidad del servicio fue mantenida incluso cuando el backend principal se encontraba fuera de servicio.	56
Interpretación : La arquitectura híbrida incrementa significativamente la resiliencia operacional.	56
5.3 Comparativa con Soluciones Existentes.....	56
5.3.1 EMCALI Cyber vs Tenable.....	56
Ventaja EMCALI Cyber: Mayor capacidad interpretativa.	56
5.3.2 EMCALI Cyber vs Qualys	56
Ventaja EMCALI Cyber: Soberanía tecnológica y ejecución local.....	56
5.3.3 EMCALI Cyber vs Rapid7	56
Ventaja EMCALI Cyber	57
5.3.4 EMCALI Cyber vs OpenVAS	57
Ventaja EMCALI Cyber	57
Tabla 5.2 Comparativa de Capacidades	57
.....	57
5.4 Discusión de Resultados	57
5.4.1 Fortalezas	57
Arquitectura híbrida	57
Reducción de costos	57
Soberanía de datos	58
Modularidad	58
Escalabilidad funcional	58
5.4.2 Debilidades	58
Dependencia de hardware	58
Calidad de datos	58
Curva de aprendizaje	58
5.4.3 Riesgos	58
Riesgos técnicos : Alucinaciones de modelos, Sesgos de entrenamiento, Dependencia de conectividad cloud.	58

Riesgos operativos: Errores de configuración, Actualizaciones de modelos.	58
Riesgos organizacionales: Resistencia al cambio, Adopción tecnológica.	58
5.4.4 Escalabilidad	58
Nivel 1 : Gestión de Vulnerabilidades Asistida por IA.	58
Nivel 2 : RAG Corporativo.	59
Nivel 3 : Agentes Especializados.....	59
Nivel 4 : SOC Inteligente.	59
Nivel 5 : Centro Autónomo de Operaciones de Seguridad basado en IA.	59
CAPÍTULO VI - CONCLUSIONES Y TRABAJOS FUTUROS	60
6.1 Conclusiones	60
6.1.2 Viabilidad de los Modelos de Lenguaje Locales para la Gestión de Vulnerabilidades	60
6.1.3 Ollama como Mecanismo de Soberanía Tecnológica	60
6.1.4 Efectividad de la Arquitectura Híbrida de Inteligencia Artificial	61
6.1.5 Impacto de la Arquitectura RAG en la Calidad del Análisis	61
6.1.6 Contribución a la Soberanía Digital y Transformación Tecnológica	62
6.1.7 Cumplimiento de los Objetivos de Investigación.....	62
6.2 Trabajos Futuros	62
6.2.1 Evolución hacia EMCALI Cyber 3.0.....	62
6.2.2 Integración con SIEM.....	63
6.2.3 Integración con SOAR.....	63
6.2.4 Integración con XDR.....	63
6.2.5 Arquitecturas Multiagente	63
Agente Analista: Interpreta vulnerabilidades.....	63
Agente de Riesgo : Prioriza amenazas.	63
Agente de Remediación: Genera planes de acción.	63
Agente Auditor: Verifica cumplimiento normativo.	63
Agente Ejecutivo: Produce informes estratégicos.....	63
6.2.6 Gemelos Digitales de Ciberseguridad (Cyber Digital Twin)	64
6.2.7 Inteligencia Artificial Predictiva para Explotación de Vulnerabilidades	64

6.2.8 Centro Autónomo de Operaciones de Seguridad (Autonomous SOC).....	64
6.2.9 Reflexión Final.....	64

Lista de Tablas

Tabla 1 - Escala de severidad	21
Tabla 2 - Comparación de parámetros	23
Tabla 3 - IEEE	31
Tabla 4 - ACM Library	31
Tabla 5 - Springer	32
Tabla 6 - Science Direct - Elsevier	32
Tabla 7 - Scopus	33
Tabla 8 - Otras Fuentes	33
Tabla 9 - Comparación Experimental de Modelos	55
Tabla 10 - Comparativa de Capacidades	57

Lista de Ilustraciones

Ilustración 1 -Figura 2.1 Poster Aplicación	30
Ilustración 2 - Aplicacion EMCALI Cyber 2.0 hibrida con Ollama	34
Ilustración 3 - Modelo único de Arquitectura	36
Ilustración 4 - Diagrama Logico de Capas	36
Ilustración 5 - Topología Funcional	39
Ilustración 6 - Diagrama único de Arquitectura	43
Ilustración 7- Diagrama de Componentes	47
Ilustración 8 - Diagrama RAG.....	48
Ilustración 9 - Diagrama de Despliegue	49
Ilustración 10 - Diagrama de Secuencia	49
Ilustración 11 - Topología Funcional.....	50

Resumen

La gestión de vulnerabilidades constituye uno de los principales desafíos de ciberseguridad en organizaciones que administran infraestructuras críticas, debido al creciente volumen de hallazgos generados por herramientas de análisis como Tenable, Qualys, OpenVAS, NVD, CISA KEV y EPSS. Aunque estas plataformas permiten identificar debilidades de seguridad, los procesos de análisis, correlación, priorización y remediación continúan requiriendo un alto nivel de intervención humana, generando sobrecarga operativa, tiempos prolongados de respuesta y dificultades para la toma de decisiones oportunas.

En este contexto, la presente investigación propone el diseño e implementación de **EMCALI Cyber 2.0 Híbrido Enterprise V12**, una plataforma inteligente para la gestión defensiva de vulnerabilidades basada en Inteligencia Artificial Generativa, Modelos de Lenguaje de Gran Escala (LLM), Recuperación Aumentada por Generación (RAG), agentes inteligentes e inferencia híbrida local-nube. La solución integra mecanismos de ingesta multiformato, normalización de información, análisis automatizado de vulnerabilidades, evaluación de riesgos, generación de recomendaciones de remediación y producción de informes técnicos y ejecutivos, operando sobre una arquitectura modular orientada a la automatización de procesos de ciberseguridad.

La plataforma prioriza la ejecución local mediante Ollama y modelos abiertos como Phi-3 Mini, TinyLlama, Gemma, Mistral y Llama 3.1, fortaleciendo la soberanía de datos institucionales y reduciendo la dependencia de servicios externos. Adicionalmente, incorpora mecanismos de conmutación inteligente hacia servicios de inteligencia artificial en la nube, como Gemini y OpenAI, garantizando continuidad operativa y resiliencia ante limitaciones de recursos computacionales. Complementariamente, se implementa una arquitectura RAG empresarial que integra conocimiento proveniente de estándares, procedimientos institucionales, documentación técnica y fuentes de inteligencia de amenazas, mejorando la precisión de los análisis y reduciendo la generación de respuestas no fundamentadas.

La validación experimental fue realizada sobre diferentes plataformas de hardware de recursos limitados y empresariales, demostrando la viabilidad técnica de ejecutar modelos de lenguaje localmente en entornos corporativos. Los resultados obtenidos evidencian una reducción significativa en los tiempos de análisis, una mejora en la consistencia de los procesos de priorización de riesgos y una mayor capacidad para transformar grandes volúmenes de información técnica en conocimiento accionable para la toma de decisiones.

Como aporte principal, esta investigación propone una arquitectura soberana, escalable y orientada a la próxima generación de operaciones de seguridad asistidas por inteligencia artificial, estableciendo las bases para futuras implementaciones de sistemas multiagente, automatización avanzada de ciberseguridad y centros de operaciones de seguridad inteligentes en organizaciones de infraestructura crítica.

Palabras clave: Gestión de Vulnerabilidades, Ciberseguridad, Inteligencia Artificial Generativa, Large Language Models, Ollama, RAG, Agentes Inteligentes, Infraestructura Crítica.

Abstract

Vulnerability management has become one of the most critical processes within modern cybersecurity programs. Organizations face thousands of findings every day from commercial vulnerability assessment platforms, public threat intelligence repositories and external cybersecurity knowledge bases.

This work presents EMCALI Cyber 2.0 Hybrid Enterprise, an intelligent platform designed under a hybrid local-cloud architecture integrating Large Language Models (LLMs), Retrieval Augmented Generation (RAG), Artificial Intelligence Agents and distributed inference mechanisms.

The proposed solution enables multi-source ingestion, vulnerability normalization, contextual enrichment using NVD, CISA KEV and EPSS repositories, automatic remediation recommendation generation and executive reporting.

Results demonstrate the feasibility of applying Generative Artificial Intelligence to improve vulnerability prioritization processes, reduce analysis times and enhance decision-making capabilities in enterprise cybersecurity environments.

Keywords: Artificial Intelligence, Cybersecurity, Vulnerability Management, RAG, LLM, Ollama, Hybrid Inference.

CAPÍTULO 1. INTRODUCCIÓN

1.1 Contexto Organizacional

Las Empresas Municipales de Cali (EMCALI EICE ESP) administran servicios esenciales para la ciudad de Santiago de Cali, incluyendo energía eléctrica, telecomunicaciones, acueducto y alcantarillado.

La dependencia tecnológica de estos servicios exige elevados niveles de disponibilidad, resiliencia y protección frente a amenazas cibernéticas cada vez más sofisticadas.

En este contexto, la identificación, evaluación y remediación de vulnerabilidades se convierte en una función estratégica para garantizar la continuidad operacional y la protección de los activos digitales institucionales.

1.2 Problema de Investigación

Las herramientas tradicionales de gestión de vulnerabilidades generan grandes cantidades de hallazgos técnicos que deben ser interpretados por especialistas de seguridad.

Entre los principales problemas identificados se encuentran:

- Sobrecarga de información.
- Priorización ineficiente.
- Procesos manuales repetitivos.
- Dependencia de expertos.
- Falta de contextualización de amenazas.
- Dificultad para correlacionar múltiples fuentes.

Estas limitaciones aumentan significativamente los tiempos de respuesta y dificultan la mitigación efectiva de riesgos.

1.3 Justificación

La aparición de los modelos de lenguaje de gran tamaño (LLM) abre nuevas oportunidades para automatizar tareas tradicionalmente ejecutadas por analistas especializados.

La combinación de:

- Inteligencia Artificial Generativa.
- Sistemas RAG.
- Agentes Inteligentes.
- Bases de conocimiento especializadas.

permite construir plataformas capaces de interpretar información técnica compleja y producir recomendaciones accionables en tiempo real.

1.4 Objetivo General

Diseñar e implementar una plataforma inteligente para la gestión defensiva de vulnerabilidades mediante modelos de lenguaje, sistemas RAG y agentes de inteligencia artificial bajo una arquitectura híbrida local-nube.

1.5 Objetivos Específicos

1. Diseñar una arquitectura híbrida de inferencia.
2. Implementar mecanismos de normalización multifuente.
3. Integrar repositorios externos de inteligencia.
4. Construir capacidades RAG locales.
5. Automatizar análisis técnicos.
6. Generar recomendaciones de remediación.
7. Producir informes ejecutivos automatizados.

CAPÍTULO II - MARCO TEÓRICO Y ESTADO DEL ARTE

2.1 Vulnerabilidad

Debilidad explotable que puede comprometer la confidencialidad, integridad o disponibilidad de un activo.

¿Qué es una Vulnerabilidad?

En términos generales, una vulnerabilidad es una debilidad, fallo, brecha o defecto presente en un sistema de información, software, hardware, procedimiento de seguridad o incluso en el propio comportamiento humano. Esta debilidad puede ser aprovechada por una amenaza (como un ciberdelincuente o un software malicioso) para vulnerar la seguridad y acceder, modificar, destruir o interrumpir datos y servicios sin autorización.

Para entenderlo de forma sencilla y precisa, la vulnerabilidad es la puerta mal cerrada o el fallo en el diseño que permite que un ataque tenga éxito.

2.2 La ecuación del Riesgo

En ciberseguridad, la vulnerabilidad no actúa sola. Se suele explicar su impacto a través de esta relación:

$$\text{Riesgo} = \text{Amenaza} \times \text{Vulnerabilidad} \times \text{Impacto}$$

Amenaza: El agente externo que quiere hacer daño (un hacker, un virus).

Vulnerabilidad: La debilidad interna que tú tienes.

Impacto: El daño causado si la amenaza explota la vulnerabilidad.

Riesgo: La probabilidad de que ocurra ese desastre. Si eliminas la vulnerabilidad, el riesgo cae a cero, aunque la amenaza siga existiendo afuera.

2.3 Tipos de Vulnerabilidades (Con Ejemplos)

Las vulnerabilidades pueden clasificarse según el área donde se encuentren. Aquí te muestro las principales categorías con ejemplos del mundo real:

- **Vulnerabilidades de Software (Código o Diseño)**

Son errores cometidos por los desarrolladores al escribir el código de una aplicación o sistema operativo.

Desbordamiento de búfer (Buffer Overflow): Ocurre cuando un programa intenta almacenar más datos en un área de memoria temporal de los que puede manejar, permitiendo que un atacante inyecte código malicioso.

Inyección SQL (SQLi): Un fallo en la validación de los datos que introduce el usuario. Si un atacante escribe comandos de bases de datos en un formulario de inicio de sesión, el sistema podría ejecutarlos y darle acceso a toda la información confidencial.

- **Vulnerabilidades de Configuración**

El software puede estar perfectamente escrito, pero si se instala o administra mal, se vuelve vulnerable.

Ejemplo: Dejar las contraseñas por defecto (como admin/admin o 12345) en routers, servidores o bases de datos tras su instalación. Cualquier escáner automatizado en internet puede encontrarlos en segundos.

Ejemplo: Mantener puertos de red abiertos innecesariamente o no configurar el cifrado en las comunicaciones.

- **Vulnerabilidades de Hardware**

Defectos físicos en los componentes electrónicos o microprocesadores. Son de las más complejas de solucionar porque a veces requieren cambiar el componente físico o aplicar parches que reducen el rendimiento.

Ejemplo: Las famosas vulnerabilidades Meltdown y Spectre que afectaron a millones de procesadores a nivel mundial, permitiendo que programas maliciosos leyeran partes secretas de la memoria del computador.

- **Vulnerabilidades Humanas (El eslabón más débil)**

Las personas que interactúan con la tecnología también representan una superficie de exposición si no están capacitadas.

- Ejemplo: Falta de cultura de seguridad, lo que lleva a un empleado a caer en un ataque de Phishing (un correo falso que imita a un banco o a la gerencia) y entregar voluntariamente sus credenciales de acceso a la red corporativa.

- **Vulnerabilidades de Proceso o Procedimiento**

Deficiencias en las políticas de seguridad de una organización.

Ejemplo: No contar con una política estricta de actualización de sistemas (gestión de parches), lo que causa que los servidores sigan usando software antiguo con fallos que ya tienen solución conocida desde hace meses o años.

Un Ejemplo Práctico e Integral

Imaginemos el sistema informático de una empresa como una casa física:

1. La Vulnerabilidad: El diseño de la ventana trasera de la casa tiene un pestillo débil que se puede abrir fácilmente desde afuera con un alambre. (Esta es la debilidad técnica).

2. La Amenaza: Un ladrón que camina por el barrio buscando casas para robar. (El agente externo).
3. El Exploit (El ataque): El ladrón encuentra la ventana trasera, mete el alambre y abre el pestillo.
4. El Impacto: El ladrón entra y se roba las joyas. (La pérdida de datos o activos).

¿Cómo se soluciona en ciberseguridad?

Se aplica un parche (en la analogía, se cambia el pestillo por una cerradura de alta seguridad o se pone una reja). La amenaza (el ladrón) seguirá existiendo en la calle, pero tu vulnerabilidad ha sido mitigada, por lo que tu riesgo disminuye drásticamente.

Para entender cómo se gestionan las vulnerabilidades a escala global, la industria de la ciberseguridad creó un sistema estandarizado para identificarlas (CVE) y otro para medir qué tan graves son (CVSS).

Piénsalo como el sistema de salud pública: primero necesitas ponerle un nombre único a la enfermedad (CVE) y luego una escala de gravedad para saber si es un resfriado común o una emergencia médica (CVSS).

2.4 Sistema CVE (Common Vulnerabilities and Exposures)

El diccionario de las debilidades

El **CVE** es un listado público y gratuito de vulnerabilidades de seguridad de la información conocidas internacionalmente. Es gestionado por la corporación **MITRE** (financiada por el gobierno de EE. UU.) y funciona como un identificador único para que todo el mundo (proveedores, investigadores, ingenieros) hable exactamente del mismo problema.

¿Cómo funciona la nomenclatura?

Cada vez que un investigador o empresa descubre una vulnerabilidad nueva y se confirma, se le asigna un código único con la siguiente estructura:

CVE – [Año de reporte] – [Número secuencial]

Ejemplo real: CVE-2021-44228

- **CVE:** El estándar.
- **2021:** El año en que se registró o se hizo pública la vulnerabilidad.
- **44228:** El número único asignado a ese fallo específico (en este caso, la famosísima y crítica vulnerabilidad de **Log4j** o *Log4Shell*).

¿Por qué es importante? Antes del CVE, si una vulnerabilidad afectaba a un software, una base de datos de seguridad la llamaba "Fallo en el servidor web X", otra la llamaba "Error de desbordamiento en componente Y". Era un caos tracking. El CVE unifica el lenguaje.

2.5 CVSS (Common Vulnerability Scoring System)

El termómetro de la gravedad - Saber que una vulnerabilidad existe no es suficiente; los equipos de TI necesitan saber cuál arreglar primero. El CVSS es un sistema abierto que calcula el nivel de severidad de una vulnerabilidad y le asigna una puntuación numérica que va del 0.0 al 10.0.

¿Cómo se calcula la puntuación?

El CVSS evalúa tres grupos de métricas para llegar a la nota final:

1. **Métricas Base** (Las características intrínsecas del fallo): Esto no cambia con el tiempo ni el entorno. Evalúa cosas como:
 - Vector de ataque: ¿El hacker necesita acceso físico al equipo (\$Local\$) o puede atacarlo desde internet (\$Network\$)?
 - Complejidad del ataque: ¿Es fácil de explotar o requiere condiciones muy específicas?
 - Privilegios requeridos: ¿El atacante debe estar logueado como administrador, como usuario normal, o no necesita credenciales?
 - Impacto: ¿Qué tanto daña la Confidencialidad, Integridad y Disponibilidad (la tríada de la seguridad CIA) de los datos?
2. **Métricas Temporales** (El estado actual del fallo): Esto cambia con el tiempo. ¿Hay un código de ataque público en internet (Exploit)? ¿El proveedor ya sacó un parche oficial o todavía no hay solución?
3. **Métricas Ambientales** (El impacto en TU organización): Esto depende de tu infraestructura. No es lo mismo una vulnerabilidad de 10.0 en un servidor que está aislado y sin datos importantes, que esa misma vulnerabilidad en el servidor principal de base de datos de producción de la empresa.

La Escala de Severidad CVSS (Versión 3.x / 4.0)

Dependiendo del resultado numérico, la vulnerabilidad se clasifica en una de estas categorías:

Puntuación CVSS	Nivel de Severidad	Acción recomendada
0.0	Informativo / Ninguno	No requiere acción.
0.1 – 3.9	Bajo (Low)	Mitigar en ventanas de mantenimiento rutinarias.
4.0 – 6.9	Medio (Medium)	Parchear a mediano plazo; monitorear el tráfico.
7.0 – 8.9	Alto (High)	Prioridad alta. Parchear lo antes posible en los próximos días.
9.0 – 10.0	Crítico (Critical)	Emergencia. Parchear inmediatamente (implica detener operaciones si es necesario).

Tabla 1 - Escala de severidad

Cuando se descubre una debilidad en un sistema, el proceso estándar es:

1. Se reporta y se le asigna un número de identidad: **CVE-2026-XXXX**.
2. Los analistas evalúan el código y su impacto, y le asignan una puntuación de gravedad: **CVSS 9.8 (Crítica)**.
3. Los administradores de infraestructura y especialistas en ciberseguridad ven las alertas en sus escáneres, filtran por las de nivel "Crítico" gracias al CVSS, y aplican los parches correspondientes para proteger la red corporativa.

Si el sistema **CVSS** es el "termómetro" que mide qué tan grave o dañina podría ser una vulnerabilidad en teoría, **EPSS** y **CISA KEV** son las herramientas de inteligencia de amenazas que te dicen si los atacantes realmente están usando esa debilidad en el mundo real.

Cuando una organización gestiona miles de vulnerabilidades, corregir todo lo que tiene un CVSS Alto o Crítico es operativamente imposible. Aquí es donde **EPSS** (un modelo predictivo) y **CISA KEV** (un catálogo de hechos confirmados) salvan el día ayudando a priorizar de forma inteligente.

2.6 EPSS (Exploit Prediction Scoring System)

La bola de cristal de la ciberseguridad. El **EPSS** es un modelo basado en datos y Machine Learning gestionado por el foro internacional **FIRST** (el mismo organismo que mantiene CVSS) (Jacobs et al., 2023). Su objetivo principal no es medir el daño, sino “predecir la probabilidad de que una vulnerabilidad específica (un CVE) sea explotada en la naturaleza (en el "wild") dentro de los próximos 30 días” (Shimizu & Hashimoto, 2025).

El modelo analiza diariamente más de 1,400 variables dinámicas, como menciones en redes sociales, repositorios de código (como GitHub), reportes de firmas de seguridad y datos de honeypots (trampas informáticas) (Jacobs et al., 2023).

¿Cómo se lee el EPSS?

Cada CVE recibe dos datos todos los días:

1. **La Probabilidad (EPSS Score):** Un valor numérico entre **0.0 y 1.0** (o de 0% a 100%). Representa la probabilidad real de ataque. Un CVE con un puntaje de 0.92 significa que hay un 92% de probabilidad de ver ataques contra ese fallo en el próximo mes.
2. **El Percentil (EPSS Percentile):** Clasifica la vulnerabilidad frente a todas las demás existentes. Si está en el percentil 0.98, significa que tiene mayor probabilidad de explotación que el 98% de los CVE conocidos.

Su gran ventaja: Permite adelantarse a los atacantes. Si un fallo tiene un CVSS Medio (poca gravedad teórica) pero su EPSS se dispara a 0.85, significa que los hackers encontraron una forma masiva y fácil de usarlo. Tienes que parchearlo de inmediato.

2.7 CISA KEV (Known Exploited Vulnerabilities Catalog)

La lista negra de las certezas A diferencia de las predicciones de EPSS, el catálogo **KEV** es un registro histórico y factual. Es gestionado por la **CISA** (la Agencia de Seguridad de Infraestructura y Ciberseguridad de los Estados Unidos) y es, esencialmente, el listado oficial de vulnerabilidades que ya están siendo explotadas activamente por ciberdelincuentes para atacar organizaciones en el mundo real (Shimizu & Hashimoto, 2025).

Para que una vulnerabilidad entre al catálogo KEV, la CISA exige que cumpla estrictamente con tres condiciones (Shimizu & Hashimoto, 2025):

- 1. Tener un código CVE asignado.
- 2. Haber evidencia clara y documentada de que está siendo explotada activamente en ataques reales (no basta con un código de prueba o teoría).
- 3. Contar con una solución clara de remediación (como un parche del proveedor o una guía de mitigación directa).

¿Por qué tiene tanto impacto técnico?

Aunque la CISA es una agencia estadounidense, su catálogo se ha convertido en el estándar de oro de priorización a nivel mundial. Para las agencias gubernamentales de EE. UU., aplicar los parches de la lista KEV es de carácter obligatorio bajo tiempos muy estrictos (usualmente dos o tres semanas) (Shimizu & Hashimoto, 2025). En el sector privado y corporativo global, si un CVE entra en el KEV, la regla general es: deja lo que estás haciendo y pon este parche hoy.

Comparativa: ¿Cómo se complementan?

Para optimizar la gestión de parches en una infraestructura informática, los analistas de seguridad cruzan estas tres herramientas (Shimizu & Hashimoto, 2025):

Característica	CVSS	EPSS	CISA KEV
¿Qué mide?	Severidad técnica teórica (Impacto).	Probabilidad matemática de ataque a corto plazo.	Explotación real, activa y confirmada.
Naturaleza	Estática (rara vez cambia el puntaje base).	Dinámica (cambia diariamente según el entorno).	Factual (se añade cuando se detecta el primer ataque real).
Enfoque	¿Qué tan grave podría ser?	¿Qué tan probable es que pase pronto ?	¿Qué está pasando ahora mismo ?
Uso en Triage	Muestra el peor escenario posible.	Ayuda a prevenir ataques inminentes.	Dicta la acción de emergencia inmediata.

Tabla 2 - Comparación de parámetros

El flujo de decisión ideal (Chaining)

Un analista moderno no usa solo CVSS porque terminaría abrumado parcheando miles de alertas (Siewruk & Łask, 2026). En su lugar, utiliza una lógica de filtrado inteligente (Shimizu & Hashimoto, 2025):

1. **Prioridad 1 (Inmediata):** ¿El CVE está en el catálogo **CISA KEV**? Si la respuesta es SÍ, se despliega el parche de emergencia porque el peligro ya está tocando la puerta.
2. **Prioridad 2 (Preventiva):** ¿El CVE tiene un **EPSS** alto (ej. > 0.10 o percentil alto) y un **CVSS** considerable? Si es SÍ, se programa su mitigación rápida antes de que aparezca formalmente en el KEV.
3. **Prioridad 3 (Rutinaria):** CVEs con CVSS alto pero con un EPSS extremadamente bajo (ej. 0.001) y que no están en el KEV. Significa que, aunque el fallo es severo en teoría, nadie en el planeta está intentando atacarlo de momento. Se pueden parchar en las ventanas de mantenimiento normales de la empresa.

2.8 LLM (Large Language Model - Modelo de Lenguaje Grande)

Modelo de lenguaje entrenado con grandes volúmenes de información textual. El "cerebro" lingüístico. Un LLM es un modelo de inteligencia artificial entrenado con arquitecturas de redes neuronales profundas (principalmente *Transformers*) y volúmenes masivos de texto. Su función principal es predecir la siguiente palabra más probable en un contexto dado, lo que le permite comprender, generar, traducir y razonar utilizando lenguaje humano natural.

Ejemplos conocidos: GPT-4, Llama 3, Mistral, Phi-3.

El problema en entornos corporativos o críticos: Los LLMs comerciales más potentes (como los de OpenAI o Anthropic) corren en la nube. Enviar datos sensibles, reportes de infraestructura, topologías de red o logs de auditoría a servidores externos puede violar políticas de cumplimiento, soberanía de datos o normativas como ISO 27001.

2.9 Ollama

Framework de inferencia local para modelos de lenguaje abiertos. El motor para correr IAs de forma local y privada. Ollama es una herramienta de código abierto diseñada para empaquetar, desplegar y ejecutar LLMs de manera local en tu propia máquina o servidor, sin depender de conexiones a internet ni de APIs de terceros.

¿Cómo funciona? Descarga los modelos optimizados y cuantizados (versiones comprimidas para que consuman menos memoria RAM/VRAM) y expone una API local. Puedes comunicarte con el modelo mediante comandos en la terminal o integrarlo con tus propias aplicaciones de software.

El valor en infraestructura y ciberseguridad: Permite procesar datos confidenciales (por ejemplo, analizar configuraciones de firewalls o bases de datos de vulnerabilidades internas) con la total certeza de que ningún dato sale de la red local.

de la organización. Además, permite cambiar de modelo (pasar de un llama3 a un mistral o un modelo especializado en código como codellama) con un solo comando.

2.10 RAG Retrieval-Augmented Generation - Generación Aumentada por Recuperación

El LLM con acceso a tu propia biblioteca de documentos. Un gran problema de los LLMs es que sufren de **alucinaciones** (inventan datos con mucha seguridad) y su conocimiento está limitado a la fecha en que terminaron su entrenamiento. No conocen tus datos privados actuales.

RAG es una arquitectura de software que soluciona esto sin necesidad de reentrenar el modelo (lo cual es sumamente costoso). En su lugar, conecta el LLM a una base de datos externa de conocimiento (usualmente una base de datos de vectores).

¿Cómo funciona el flujo de un sistema RAG?

1. Ingesta: Tienes tus documentos (por ejemplo, manuales de políticas de seguridad, reportes de escaneos de vulnerabilidades, el catálogo CISA KEV actualizado, etc.). Estos documentos se dividen en fragmentos (*chunks*) y se convierten en vectores matemáticos (*embeddings*) para guardarse en una base de datos vectorial.
2. Consulta: El usuario hace una pregunta: *"¿Cuáles de nuestros servidores están expuestos a vulnerabilidades críticas del catálogo KEV de este mes?"*
3. Recuperación (Retrieval): El sistema busca en la base de datos vectorial los fragmentos de documentos más relevantes relacionados con la pregunta.
4. Aumentación (Augmentation): El sistema toma la pregunta original del usuario y le "pega" los fragmentos de información real encontrados.
5. Generación (Generation): El LLM recibe el paquete completo (*"Con base en este contexto adjunto, responde la pregunta..."*). El modelo redacta una respuesta precisa, verídica y fundamentada estrictamente en tus datos, eliminando las alucinaciones.

El Ecosistema Completo: ¿Cómo se unen los tres?

Si quieres construir un asistente inteligente para automatizar tareas en una organización con altos estándares de privacidad, los unes de la siguiente manera:

- Ollama actúa como la infraestructura base, levantando y exponiendo un modelo de código abierto (como Llama-3-8B) dentro de un servidor de la empresa.
- El sistema **RAG** se construye encima (usando frameworks de agentes como *LangChain* o *LangGraph*), alimentado con los documentos técnicos, inventarios de activos y logs de la empresa.
- Cuando un analista interactúa con el sistema, el LLM local procesa la información de forma segura, respondiendo preguntas complejas contextualizadas con la realidad de la organización en tiempo real.

2.11 MCP (Model Context Protocol)

El puerto USB universal para los LLMs. El Model Context Protocol (MCP) es un estándar abierto desarrollado (inicialmente por Anthropic) para resolver uno de los mayores problemas de los LLMs: **el aislamiento**.

Por lo general, cada vez que un desarrollador quiere que un modelo se conecte a una base de datos, a un repositorio de GitHub, o a una API empresarial, tiene que escribir un código de integración personalizado (*herramientas* o *tool calling*). Si cambias de modelo o de plataforma, muchas veces hay que reescribir esa lógica.

¿Cómo funciona MCP?

MCP funciona bajo una arquitectura Cliente-Servidor:

El Cliente (El LLM/Agente): Aplicaciones o entornos de desarrollo que soportan el protocolo.

El Servidor MCP: Un pequeño servicio que expone datos o herramientas de forma estandarizada. Por ejemplo, puede haber un servidor MCP para Postgres, otro para sistemas de archivos locales, o otro para interactuar con APIs de ciberseguridad.

El impacto: MCP actúa como un "conector universal". Un solo servidor MCP puede servir para que cualquier modelo compatible lea archivos corporativos, consulte bases de datos o ejecute comandos de forma segura, estructurada y bajo el control estricto de la infraestructura local.

2.12. LangGraph

El cerebro de control para agentes basados en grafos. Si ya conoces frameworks como *LangChain*, sabrás que son excelentes para flujos lineales (Paso → A Paso → B → Paso C). Sin embargo, los agentes de IA del mundo real no trabajan en línea recta; requieren ciclos, bucles de retroalimentación y toma de decisiones complejas. Aquí es donde entra LangGraph.

LangGraph es una biblioteca diseñada para construir aplicaciones multi-agente y flujos de trabajo cíclicos utilizando una estructura de Grafo Dirigido (Directed Graph).

Componentes clave de LangGraph:

Nodos (Nodes): Representan acciones o pasos individuales. Un nodo puede ser una llamada a un LLM (por ejemplo, vía Ollama), la ejecución de una función de código, o una consulta a una base de datos.

Bordes (Edges): Definen la dirección del flujo de un nodo a otro.

Bordes Condicionales (Conditional Edges): Permiten al sistema tomar decisiones enrutadas por un LLM. *Por ejemplo: Si el LLM determina que la respuesta del Nodo A necesita más datos, el borde condicional redirige el flujo de vuelta al Nodo A en lugar de avanzar al final.*

Estado (State): Una memoria centralizada que persiste y se comparte a lo largo de todo el grafo. Cada nodo puede leer o escribir en este estado, permitiendo que el agente no "olvide" lo que hizo en pasos anteriores.

La Sinergia: MCP + LangGraph + Ollama + RAG

Para entender el poder de estas tecnologías, imagina el diseño de un Agente Avanzado de Operaciones o Ciberseguridad que corra de manera local en una empresa:

1. La Infraestructura y el Conocimiento (Ollama + RAG): Tienes un LLM corriendo localmente en la red con Ollama y un sistema RAG conectado a toda la documentación interna de la infraestructura.
2. La Lógica de Control (LangGraph): Diseñas un grafo donde:
 - Nodo 1: Recibe una alerta del sistema.
 - Nodo 2 (LLM): Analiza la alerta y decide si es un falso positivo.
 - Borde Condicional: Si es sospechoso, envía el flujo al Nodo 3, si no, finaliza el flujo.
 - Nodo 3 (Acción): Ejecuta una herramienta de mitigación o aislamiento.
3. La Conexión con el Mundo Real (MCP): Para que el Nodo 3 pueda interactuar con los servidores, servidores de bases de datos o firewalls reales de la organización sin reescribir código complejo, utiliza un Servidor MCP seguro que le da acceso controlado al agente para ejecutar comandos específicos en la infraestructura.

2.13 LangChain

La navaja suiza para el desarrollo con LLMs. El framework que prácticamente inauguró la era del desarrollo de aplicaciones basadas en Modelos de Lenguaje Grandes (LLMs).

LangChain es un framework de código abierto (disponible en Python y JavaScript) diseñado para simplificar drásticamente la creación de aplicaciones que combinan LLMs con fuentes de datos externas, APIs y lógica de programación tradicional.

Antes de LangChain, si querías conectar un modelo a una base de datos o estructurar un prompt, tenías que escribir todo el código de integración desde cero. LangChain llegó para estandarizar este proceso proporcionando bloques de construcción modulares.

Los Componentes Clave de LangChain

LangChain se organiza en varios módulos Core que permiten estructurar cualquier aplicación de IA:

- Modelos (Models & I/O)

Estandariza la interfaz para interactuar con cualquier proveedor de IA. No importa si usas un modelo comercial en la nube o un modelo local mediante Ollama; la sintaxis de LangChain para enviar prompts y recibir respuestas estructuradas es exactamente la misma.

- Prompts (Prompt Templates)

En lugar de escribir texto plano, LangChain permite crear plantillas dinámicas.

Ejemplo: Una plantilla que recibe variables de entrada: "Eres un experto en infraestructura. Analiza el siguiente log de error: {log_servidor} y genera una recomendación."

- Cadenas (Chains / LCEL)

Este es el corazón del framework. A través de LCEL (LangChain Expression Language), puedes encadenar componentes de forma limpia usando el operador pipe (`|`).

Ejemplo de una cadena básica: Template | LLM | OutputParser (Toma el prompt dinámico, lo pasa al modelo y luego formatea la respuesta en un JSON limpio).

Este es el corazón del framework. A través de LCEL (LangChain Expression Language), puedes encadenar componentes de forma limpia usando el operador pipe (`|`).

Ejemplo de una cadena básica: Template | LLM | OutputParser (Toma el prompt dinámico, lo pasa al modelo y luego formatea la respuesta en un JSON limpio).

- Memoria (Memory)

Por naturaleza, las APIs de los LLMs son *stateless* (no recuerdan la pregunta anterior). LangChain proporciona componentes de memoria para almacenar el historial de la conversación, permitiendo que el modelo mantenga el contexto en un chat técnico o corporativo.

- Recuperadores (Retrieval)

Es el módulo diseñado específicamente para construir sistemas RAG. Facilita todo el flujo: desde cargar archivos (PDFs, Markdown, código), dividirlos en fragmentos, conectarse a bases de datos vectoriales (como Chroma, Pinecone o PGVector), hasta recuperar los fragmentos más relevantes ante una consulta.

- Agentes (Agents & Tools)

Permite que el LLM actúe como un motor de razonamiento que decide qué herramientas usar. Si el modelo no sabe la respuesta a una pregunta, puede decidir de forma autónoma ejecutar una herramienta (por ejemplo, buscar en internet, ejecutar una consulta SQL o consumir un servidor MCP).

- La Evolución: De LangChain a LangGraph

Es muy común confundir o mezclar estos dos términos, pero su propósito actual está muy bien definido en el ecosistema:

- LangChain es excelente para flujos de trabajo **lineales y secuenciales** (Toma un documento → Extrae el resumen → Tradúcelo → Guárdalo). Es la base de datos, los conectores y las herramientas.
- LangGraph (que es una extensión del ecosistema de LangChain) se diseñó porque las cadenas lineales se quedaban cortas para agentes complejos. LangGraph introduce la capacidad de crear bucles y grafos cíclicos (Toma una acción → Evalúa el resultado → Si falló, regresa al paso anterior y corrige).

El Panorama Completo

Haciendo un mapa mental de todo lo que hemos definido, una arquitectura robusta, moderna y privada de IA se ve así:

- Ollama: Aloja el cerebro (LLM) de forma local y segura en tus servidores.
- LangChain: Proporciona los conectores de datos, las plantillas de prompts y la estructura RAG para alimentar al cerebro con la información de tu organización.
- Model Context Protocol (MCP): Actúa como el puente estandarizado para que la IA interactúe de forma segura con bases de datos y herramientas externas.
- LangGraph: Orquesta todo el comportamiento, permitiendo que múltiples agentes colaboren, tomen decisiones en bucle y resuelvan problemas complejos de infraestructura o seguridad de principio a fin.



EMCALI Cyber 2.0 HÍBRIDO ENTERPRISE

ARQUITECTURA, DIAGRAMAS, DISEÑO Y DOCUMENTO TÉCNICO INTEGRADO

Agente Consultor en Ciberseguridad con LLMs Locales (Ollama) + Híbridos (Cloud)

Análisis de Vulnerabilidades | RAG Local | MCP Tools | LangGraph | Ollama | FastAPI | Streamlit



1. RESUMEN EJECUTIVO

EMCALI Cyber 2.0 Híbrido Enterprise es una plataforma local-first e híbrida que integra modelos de lenguaje locales (Ollama) y modelos en la nube (OpenAI, Anthropic, Gemini) para el análisis inteligente de vulnerabilidades y la generación de recomendaciones técnicas. Su arquitectura modular y por capas permite ingestar múltiples formatos de datos (Qualys, Tenable, CSV, JSON, Excel, NVD, CISA KEV, EPSS), normalizarlos en un esquema unificado y encadenar todos los módulos mediante `session_state`, garantizando que los hallazgos cargados en la ingesta se propaguen a todo el sistema: Tablero, Análisis LLM, Riesgo, Remediación, RAG, Informes y Métricas.

2. PRINCIPIOS DE DISEÑO

- Soberanía de datos**
Procesamiento local por defecto. Los datos sensibles no salen del entorno autorizado salvo configuración explícita.
- Arquitectura tool-driven**
El agente utiliza herramientas (MCP) y fuentes verificables. No depende únicamente del prompt.
- Multi-formato y normalización previa**
Soporta múltiples formatos y los transforma a un esquema unificado antes de su análisis.
- Encadenamiento completo por sesión**
El dataset activo se almacena en `session_state` y se comparte entre todos los módulos.
- Inferencia híbrida**
Selección dinámica de backend: Ollama (local) o proveedores en la nube.
- RAG + Enriquecimiento externo**
Contexto local + fuentes externas (NVD, CISA KEV, EPSS) para aumentar precisión y reducir alucinaciones.
- Trazabilidad y evaluación**
Historial de análisis, métricas LLM, evaluaciones y reportabilidad completa.
- Despliegue on-premise**
Funciona en equipos sin internet, con posibilidad de nube controlada.

3. INGESTA MULTIFORMATO Y NORMALIZACIÓN

Formato de entrada	Descripción	Proceso de normalización
CSV	Exportaciones de Qualys, Tenable, NVD, CISA, EPSS	✓ Detección automática del formato
Excel (.xlsx / .xls)	Información de inventarios, hallazgos o vulnerabilidades	✓ Mapeo flexible de columnas
JSON	APIs, exportaciones o esquemas personalizados	✓ Cálculo de severidad y CVSS
Qualys	Mapeo de QID, título, severidad, CVSS, detección, solución	✓ Derivación de exploitability (CVSS + EPSS + KEV)
Tenable / Nessus	Mapeo de Plugin ID, familia, severidad, CVSS, evidencia	✓ Esquema unificado (Unified Schema)
NVD + CISA + EPSS	Datasets enriquecidos: <code>cve_cisa_epss_enriched_dataset.csv</code>	✓ Carga en <code>session_state</code>
<code>cve_corpus.csv</code>	Corpus de CVEs con descripciones y métricas	✓ Propagación a todos los módulos
Otros	Cualquier dataset que cumpla el mapeo configurable	

4. MÓDULOS DE LA APLICACIÓN Y ENCADENAMIENTO

Módulo	Descripción	Fuente de datos	Resultado principal
1. Tablero	Visión ejecutiva y métricas generales	dataset activo	KPIs, gráficos y estado
2. Ingesta	Carga y normalización de archivos	archivos del usuario	Dataset unificado activo
3. Análisis LLM	Explicación técnica con LLM	dataset activo + RAG	Respuesta técnica + JSON
4. Riesgo	Cálculo de riesgo y priorización	dataset activo	Matriz, heatmap, tabla
5. Remediación	Recomendaciones y playbooks	dataset activo + RAG	Acciones y scripts
6. RAG Local	Consulta de conocimiento local y enriquecimiento externo	KB local + NVD + CISA + EPSS	Contexto + evidencias
7. Informes	Generación de informes ejecutivos y técnicos	dataset activo + análisis	PDF / DOCX / CSV / JSON
8. Métricas LLM	Evaluación de calidad de respuestas	historial + dataset activo	Métricas y gráficas
9. Configuración	Backends, modelos, RAG, API keys	configuración del usuario	Parámetros guardados

El dataset activo cargado en la ingesta se almacena en `session_state("findings_df")` y se comparte con todos los módulos, garantizando consistencia total de los datos.

5. BACKENDS DE LLM SOPORTADOS

Ollama (Local)	OpenAI	Anthropic	Google Gemini
• Privacidad total • Sin costo por token • Modelos: llama3.1.8b, foundation-sec-8b, etc.	• GPT-4o, GPT-4o-mini • Alta calidad • Requiere API Key	• Claude 3.5 Sonnet/Haiku • Excelente razonamiento • Requiere API Key	• Gemini 1.5 Pro • Contexto amplio • Requiere API Key

6. CARACTERÍSTICAS PRINCIPALES

- ✓ Ingesta multiformato con detección automática y mapeo flexible.
- ✓ Normalización a esquema unificado con CVSS, severidad y exploitability.
- ✓ Encadenamiento completo entre todos los módulos por `session_state`.
- ✓ RAG local con base vectorial + enriquecimiento externo (NVD, CISA KEV, EPSS).
- ✓ Backends híbridos: Ollama (local) + Cloud (OpenAI, Anthropic, Gemini).
- ✓ Generación de informes en PDF, DOCX, CSV y JSON.
- ✓ Métricas de evaluación de LLM con historial y comparativas.
- ✓ Despliegue en Windows con `.exe`, `.zip` portable y Setup.
- ✓ Funcionamiento en equipos sin GPU (CPU) y con GPU dedicada.

8. BENEFICIOS PARA EMCALI

- ✓ Privacidad y control total de los datos sensibles.
- ✓ Mayor precisión y menor tasa de alucinaciones gracias a RAG y fuentes verificables.
- ✓ Automatización del análisis de vulnerabilidades y generación de remediaciones.
- ✓ Priorización basada en riesgo real (CVSS, EPSS, KEV, contexto activo).
- ✓ Informes ejecutivos y técnicos listos para auditoría y gestión.
- ✓ Escalabilidad: nuevos modelos, nuevas fuentes y nuevos casos de uso.

9. HOJA DE RUTA SUGERIDA

- 1 Fase 1: Ingesta + Normalización + Tablero + Análisis LLM
- 2 Fase 2: Riesgo + Remediación + Informes
- 3 Fase 3: RAG Local + Enriquecimiento Externo
- 4 Fase 4: Métricas LLM + Evaluación avanzada
- 5 Fase 5: Integración con SIEM / Tickets / SOAR

7. DIAGRAMAS DE LA ARQUITECTURA HÍBRIDA ENTERPRISE

DIAGRAMA 1. ARQUITECTURA GENERAL (MODELO ÚNICO)

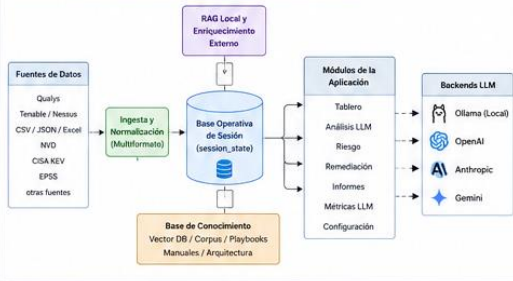


DIAGRAMA 2. DIAGRAMA LÓGICO POR CAPAS

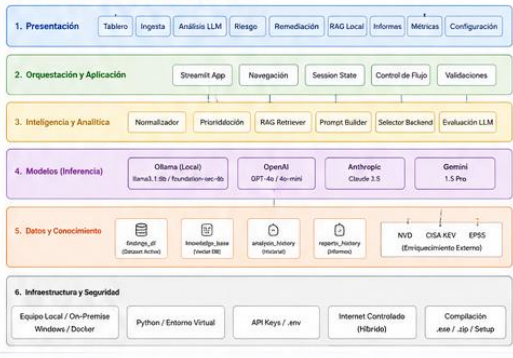


DIAGRAMA 3. TOPOLOGÍA FUNCIONAL Y FLUJO DE DATOS

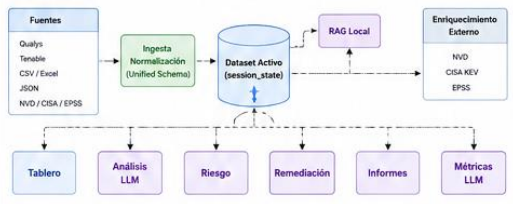


DIAGRAMA 4. DESPLIEGUE ON-PREMISE

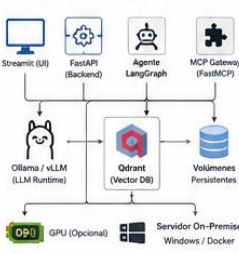
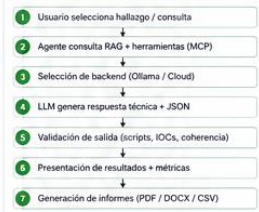


DIAGRAMA 5. FLUJO DE ANÁLISIS CON LLM



Tecnologías Clave

Modelos Soportados

Formatos Soportados

EMCALI Cyber 2.0 Híbrido Enterprise

Ilustración 1 -Figura 2.1 Poster Aplicación

2.14 Estado del Arte (2022-2026)

1. IEEE	
NOMBRE	1. Large Language Models for Cyber Security: A Systematic Literature Review (2024)
AUTOR	Hanxiang Xu et al.
ENLACE	IEEE/ArXiv Paper
APORTE	Revisión sistemática de 127 artículos. Aplicación de LLM en: Vulnerability Detection, Malware Analysis, Threat Hunting, Intrusion Detection.
NOMBRE	2. Review on Large Language Models: Architectures, Applications, Taxonomies, Open Issues and Challenges (2024)
AUTOR	Mohaimenul Azam Khan Raiaan
ENLACE	https://ieeexplore.ieee.org/stamp/stamp.jsp?tp=&arnumber=10433480
APORTE	Arquitecturas LLM, Aplicaciones empresariales, Limitaciones y riesgos de seguridad
NOMBRE	3. The Security of Using Large Language Models: A Survey (2025)
AUTOR	Wei Zhou , Xiaogang Zhu
ENLACE	https://www.ieee-jas.com/en/article/doi/10.1109/JAS.2024.124983?utm_source=chatgpt.com
APORTE	Riesgos de seguridad de ChatGPT y LLM. Ataques adversariales. Privacidad y seguridad.
NOMBRE	4. Devising and Detecting Phishing Emails Using Large Language Models (2024)
AUTOR	Autores: FRED HEIDING 1,2, BRUCE SCHNEIER
ENLACE	https://ieeexplore.ieee.org/stamp/stamp.jsp?tp=&arnumber=10466545
APORTE	Uso dual de IA ofensiva y defensiva. Detección inteligente de phishing.
NOMBRE	5. Security Risk Taxonomy for Prompt-Based Interaction with LLMs (2024)
AUTOR	ERIK DERNER 1,2, KRISTINA BATISTIĆ
ENLACE	https://ieeexplore.ieee.org/stamp/stamp.jsp?tp=&arnumber=10648691
APORTE	Taxonomía de riesgos asociados a LLM, Prompt Injection. Data Leakage

Tabla 3 - IEEE

2. ACM Digital Library	
NOMBRE	1. Large Language Models for Cyber Security: A Systematic Literature Review
AUTOR	Hanxiang Xu, Shenao Wang, Ningke Li,
ENLACE	https://dl.acm.org/doi/epdf/10.1145/3769676
APORTE	Estado del arte de IA aplicada a ciberseguridad. Análisis de tendencias de investigación.
NOMBRE	2. Security Vulnerability Analysis Using Penetration Testing (2023)
AUTOR	Muhammad Fakhru Safitra,
ENLACE	https://dl.acm.org/doi/10.1145/3592307.3592329
APORTE	Vulnerability Assessment. Pentesting automatizado Nessus y Nmap.
NOMBRE	3. Automated Software Vulnerability Patching using LLMs (2024)
AUTOR	Yu Nong, Haoran Yang, Long Cheng
ENLACE	https://arxiv.org/pdf/2408.13597
APORTE	Remediación automática de vulnerabilidades mediante LLM., Comparación frente a herramientas tradicionales.
NOMBRE	4. VulDetectBench: Evaluating Vulnerability Detection with LLMs (2024)
AUTOR	jiutianhuayu.github.io
ENLACE	https://github.com/Sweetaroo/VulDetectBench
APORTE	Benchmark de detección de vulnerabilidades., Comparación entre LLM.
NOMBRE	5. LLM-Assisted Static Analysis for Detecting Security Vulnerabilities (2024)
AUTOR	Ziyang Li - https://github.com/huhusmang/Awesome-LLMs-for-Vulnerability-Detection
ENLACE	https://www.researchgate.net/publication/380907111_LLM-Assisted_Static_Analysis_for_Detecting_Security_Vulnerabilities
APORTE	Análisis estático asistido por IA., Detección temprana de fallas de seguridad.

Tabla 4 - ACM Library

3. Springer						
NOMBRE	1. Do LLMs Consider Security? An Empirical Study (2025)					
AUTOR	Amirali Sajad, Binh Le					
ENLACE	https://link.springer.com/article/10.1007/s10664-025-10658-6					
APORTE	Evaluación de GPT-4, Claude y Llama 3., Seguridad en generación de código.					
NOMBRE	2. Large Language Model Based Vulnerability Detection (2025)					
AUTOR	Cho Do Xuan, Dat Bui Quang & Vinh Dang Quang					
ENLACE	https://link.springer.com/article/10.1007/s10207-025-00983-8					
APORTE	Detección automática de vulnerabilidades., Ensemble Learning + LLM.					
NOMBRE	3. Cybersecurity Vulnerability Assessment Methodology (2024)					
AUTOR	Jon Hurtado, C. Birk Jones, Jay Johnson & Brian Wright					
ENLACE	https://www.osti.gov/servlets/purl/2480142					
APORTE	Framework de evaluación de vulnerabilidades., Buenas prácticas empresariales.					
NOMBRE	4. Security Awareness of LLMs in Software Development (2025)					
AUTOR	Amirali Sajadi, Binh Le, Anh Nguyen, Kostadin Damevski & Preetha Chatterjee					
ENLACE	https://link.springer.com/article/10.1007/s10664-025-10658-6					
APORTE	Seguridad en desarrollo asistido por IA.					
NOMBRE	5. Vulnerability Detection in Large Language Models (2025)					
AUTOR	Sahar Ben Yaala * and Ridha Bouallegue					
ENLACE	https://www.mdpi.com/2624-800X/5/3/71					
APORTE	Vulnerabilidades propias de LLM, Riesgos operacionales.					

Tabla 5 - Springer

4. Science Direct -Elsevier						
NOMBRE	CyberLLaMA: A fine-tuned large language model for cybersecurity named entity recognition					
AUTOR	Hao Zhang a					
ENLACE	https://www.sciencedirect.com/science/article/pii/S0950705125012249					
APORTE	Modelo de lenguaje extenso para el reconocimiento de entidades nombradas en ciberseguridad					
NOMBRE	SecLMNER: A framework for enhanced named entity recognition in multi-source cybersecurity data using large language models					
AUTOR	Yunlong ZhangJingju LiuLei Wu					
ENLACE	https://www.sciencedirect.com/science/article/pii/S2213846325001701					
APORTE	Un marco para mejorar el reconocimiento de entidades nombradas en datos de ciberseguridad de múltiples fuentes mediante modelos de lenguaje extensos.					
NOMBRE	Automated Generation of Cybersecurity Response Playbooks via Large Language Models					
AUTOR	Ciprian PaduraruBogdan DumitruAlin Stefanescu					
ENLACE	https://www.sciencedirect.com/science/article/pii/S1877050925030960					
APORTE	Generación automatizada de manuales de respuesta ante ciberataques mediante modelos de lenguaje a gran escala.					
NOMBRE	Large Language Models for Cybersecurity Intelligence: A Systematic Review of Emerging Threats, Defensive Capabilities, and Security Evaluation Frameworks					
AUTOR	Hamed Alqahtani 1					
ENLACE	https://www.sciencedirect.com/org/science/article/pii/S1546221826003565 - https://www.techscience.com/cmc/v87n3/66964/pdf					
APORTE	revisión sistemática de las amenazas emergentes, las capacidades defensivas y los marcos de evaluación de la seguridad					
NOMBRE	Assessing the cybersecurity of connected 3D printers using large language models (LLMs)					
AUTOR	Shi Yong GohAnkush Mishra					
ENLACE	https://www.sciencedirect.com/science/article/pii/S2213846325001701					
APORTE	Evaluación de la ciberseguridad de impresoras 3D conectadas mediante modelos de lenguaje extensos.					

Tabla 6 - Science Direct - Elsevier

5. Scopus (Artículos altamente indexados)	
NOMBRE	CVE-LLM : Ontology-Assisted Automatic Vulnerability Evaluation Using Large Language Models
AUTOR	Rikhiya Ghosh, Hans-Martin von Stockhausen, Martin Schmitt, George Marica Vasile, Sanjeev Kumar Karn, Oladimeji Farri
ENLACE	https://arxiv.org/pdf/2502.15932
APORTE	Evaluación de vulnerabilidades en LLMs
NOMBRE	A review of cybersecurity in smart cities and intelligent transport systems
AUTOR	Joshi, Sujata
ENLACE	https://link.springer.com/article/10.1007/s43926-026-00312-y
APORTE	Una revisión de la ciberseguridad en ciudades inteligentes y sistemas de transporte inteligentes.
NOMBRE	A generative AI cybersecurity risks mitigation model for code generation: using ANN-ISM hybrid approach
AUTOR	Al-Hashimi, Hussein A
ENLACE	https://www.nature.com/articles/s41598-025-34350-3
APORTE	Un modelo generativo de IA para la mitigación de riesgos de ciberseguridad en la generación de código: uso de un enfoque híbrido ANN-ISM.
NOMBRE	Cybersecurity in critical rail infrastructure: sector specific adoption of the NIS 2 directive in Europe
AUTOR	Oka, Mimi Enakome
ENLACE	https://link.springer.com/article/10.1007/s12198-026-00349-8
APORTE	Ciberseguridad en infraestructuras ferroviarias críticas: adopción sectorial de la directiva NIS 2 en Europa
NOMBRE	Integrated risk scoring and exploit prediction for cyber-physical power system vulnerabilities
AUTOR	Kausar, Firdous
ENLACE	https://link.springer.com/article/10.1186/s42162-026-00640-x
APORTE	Sistema integrado de puntuación de riesgos y predicción de vulnerabilidades en sistemas de energía ciberfísicos.

Tabla 7 - Scopus

6. Otras Fuentes	
NOMBRE	1. Large Language Model Based Hybrid Framework for Cybersecurity Vulnerability Detection (2025)
AUTOR	Nihala Basheer, Shareeful Islam shareeful.islam@aru.ac.uk, [...], and Spyridon Papastergiou
ENLACE	https://journals-sagepub-com.us1.proxy.openathens.net/doi/full/10.1177/10692509251368663
APORTE	Meta-learning., Fine-tuning para detección de vulnerabilidades.
NOMBRE	2. Large Language Models in Cybersecurity: Applications, Vulnerabilities and Defense Techniques (2025)
AUTOR	Niveen Jaffal, David Mohaisen
ENLACE	https://www.researchgate.net/publication/393852332_Large_Language_Models_in_Cybersecurity_Applications_Vulnerabilities_and_Defense_Techniques
APORTE	Defensa y ataque mediante IA., Estado del arte integral.
NOMBRE	3. Large Language Models for Cybersecurity Intelligence, Threat Hunting and Vulnerability Analysis (2025)
AUTOR	Shaochen Ren, Shiyang Chen
ENLACE	https://computer-life.org/index.php/ojs/article/view/27
APORTE	Cyber Threat Intelligence., Threat Hunting automatizado.
NOMBRE	4. Automated Software Vulnerability Patching Using LLMs (2024)
AUTOR	Yu Nong, Haoran Yang
ENLACE	https://arxiv.org/html/2408.13597v1
APORTE	Corrección automática de vulnerabilidades.
NOMBRE	5. ChatNVD: Advancing Cybersecurity Vulnerability Assessment with LLMs (2024)
AUTOR	Shivansh Chopra, Hussain Ahmad, Diksha Goel, Claudia Szabo
ENLACE	https://arxiv.org/abs/2412.04756
APORTE	Uso de NVD + GPT + Gemini + Llama., Muy cercano al concepto EMCALI Cyber 2.0.

Tabla 8 - Otras Fuentes

CAPÍTULO III - METODOLOGÍA Y DISEÑO DE LA SOLUCIÓN

3.1 Tipo de Investigación

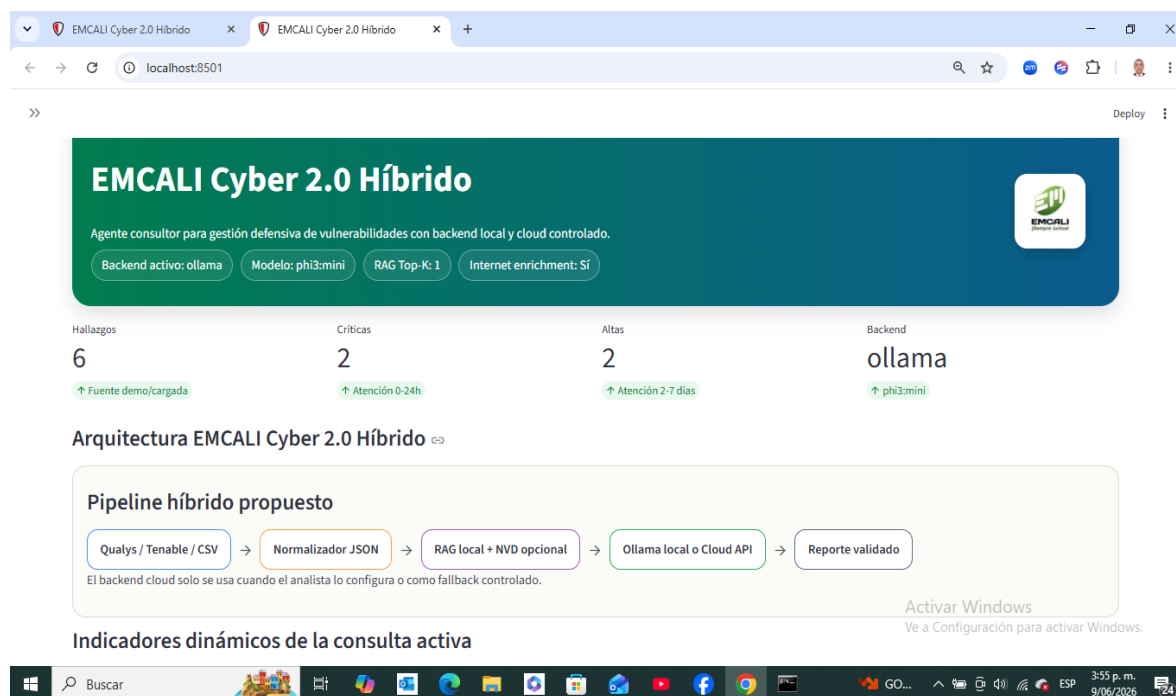


Ilustración 2 - Aplicación EMCALI Cyber 2.0 híbrida con Ollama

3.1.1 Investigación Aplicada

La presente investigación corresponde a una investigación aplicada, debido a que busca resolver un problema real asociado a la gestión defensiva de vulnerabilidades en entornos corporativos e infraestructuras críticas mediante la integración de tecnologías emergentes de Inteligencia Artificial, modelos de lenguaje de gran escala (LLM), sistemas RAG y mecanismos de inferencia híbrida.

A diferencia de las investigaciones de carácter puramente teórico, este trabajo tiene como propósito el diseño, implementación y validación de una solución tecnológica funcional denominada **EMCALI Cyber 2.0 Híbrido Enterprise**, orientada a optimizar los procesos de identificación, análisis, priorización y remediación de vulnerabilidades reportadas por plataformas especializadas de gestión de vulnerabilidades.

El proyecto se desarrolla tomando como referencia necesidades reales identificadas en los procesos de ciberseguridad empresarial, donde la creciente cantidad de vulnerabilidades descubiertas diariamente dificulta la capacidad de análisis oportuno por parte de los equipos de seguridad.

Desde esta perspectiva, la investigación aporta una solución práctica que combina técnicas de Inteligencia Artificial Generativa con metodologías modernas de gestión de riesgos cibernéticos, permitiendo transformar grandes volúmenes de información técnica en conocimiento accionable para la toma de decisiones.

3.1.2 Enfoque Mixto

La investigación adopta un enfoque mixto al integrar componentes cuantitativos y cualitativos dentro del proceso de evaluación de la solución propuesta.

Componente Cuantitativo

Se orienta a medir objetivamente variables como: Tiempo promedio de análisis de vulnerabilidades, Número de hallazgos procesados, Consumo de CPU y memoria, Tiempo de respuesta de los modelos LLM, Precisión en la clasificación de riesgos, Capacidad de procesamiento de registros, Efectividad de los mecanismos de remediación.

Componente Cualitativo

Evalúa aspectos relacionados con: Calidad de las recomendaciones generadas, Utilidad de los análisis producidos por los LLM, Interpretabilidad de los resultados, Nivel de contextualización del conocimiento recuperado mediante RAG, Facilidad de uso de la plataforma, Percepción de valor para los analistas de seguridad.

La combinación de ambos enfoques permite realizar una evaluación integral del comportamiento de la plataforma tanto desde la perspectiva técnica como desde la perspectiva operativa y organizacional.

3.1.3 Diseño Experimental

El trabajo adopta un diseño experimental debido a que se construye un entorno controlado para validar el comportamiento de la arquitectura propuesta.

Durante la fase experimental se evalúan diferentes escenarios de operación utilizando: Modelos locales ejecutados mediante Ollama, Modelos cloud basados en Gemini y OpenAI, Diferentes volúmenes de vulnerabilidades, Diversos perfiles de hardware, Múltiples configuraciones de inferencia.

Las pruebas permiten analizar el impacto de variables como: Disponibilidad de GPU, Cantidad de memoria RAM, Tipo de modelo utilizado, Calidad de las fuentes de información, Estrategias de recuperación contextual.

3.2 Arquitectura General de EMCALI Cyber 2.0 Híbrido Enterprise

La arquitectura propuesta fue diseñada siguiendo principios de modularidad, escalabilidad, resiliencia y soberanía tecnológica.

El modelo se estructura en seis capas funcionales que permiten separar responsabilidades y facilitar la evolución futura de la plataforma.

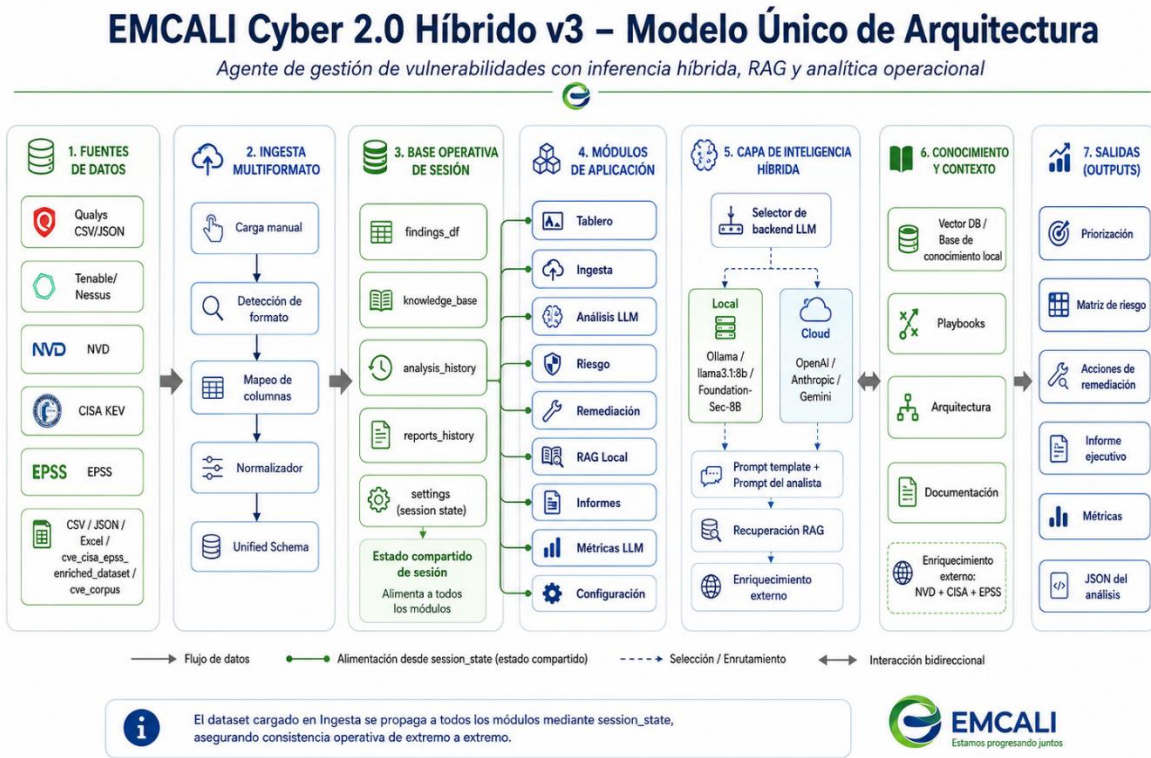


Ilustración 3 - Modelo único de Arquitectura

3.2.1 Arquitectura por Capas

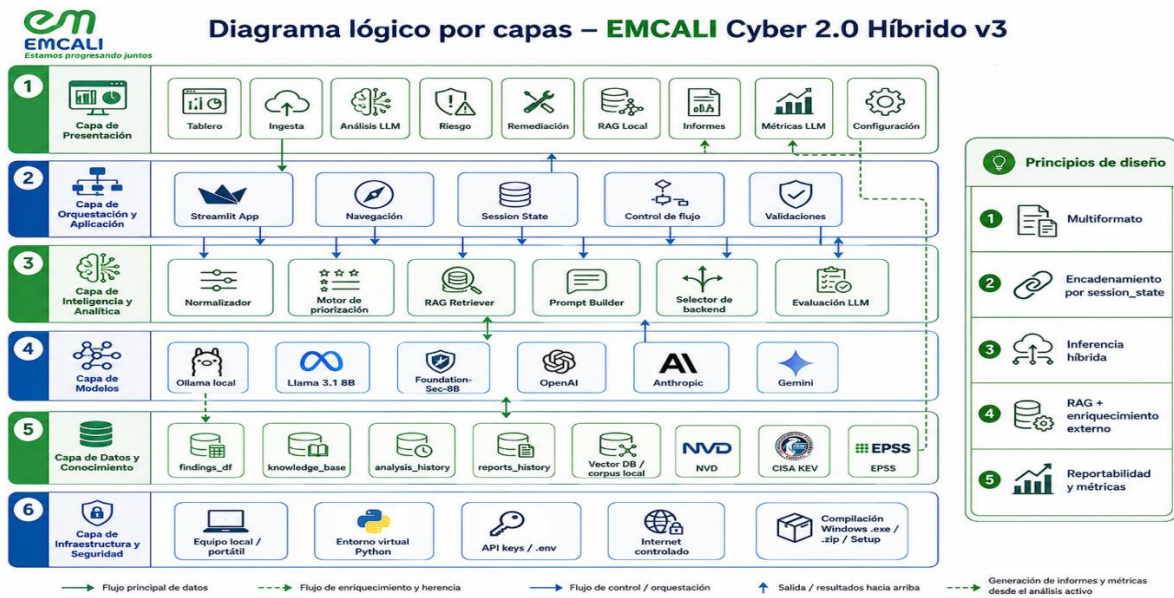


Ilustración 4 - Diagrama Logico de Capas

3.2.2 Capa 1: Fuentes de Datos

Esta capa constituye el punto de entrada de la información.

Su función consiste en recolectar vulnerabilidades provenientes de diversas fuentes especializadas.

Tenable : Plataforma líder en Vulnerability Management.

Proporciona: Vulnerabilidades detectadas, Configuraciones inseguras, Activos afectados, Métricas CVSS.

Qualys: Permite realizar: Escaneo de vulnerabilidades, Gestión de activos, Evaluación continua de riesgos.

NVD (National Vulnerability Database): Base oficial mantenida por NIST.

Contiene: CVE, CVSS, Descripciones técnicas, Referencias oficiales.

EPSS (Exploit Prediction Scoring System): Modelo predictivo desarrollado por FIRST.

Su objetivo es estimar la probabilidad de explotación de una vulnerabilidad durante los próximos 30 días.

CISA KEV: Catálogo de vulnerabilidades activamente explotadas.

Representa una de las fuentes más relevantes para priorización operativa.

3.2.2 Capa 2: Motor de Normalización (JSON Engine)

Las fuentes de vulnerabilidades generan información heterogénea.

Cada fabricante utiliza: Estructuras diferentes, Campos distintos, Niveles variables de detalle.

Para resolver este problema se desarrolló un motor de normalización basado en JSON.

Funciones principales: Estandarización de datos, Eliminación de duplicados, Homologación de atributos, Conversión a un esquema común.

Salida unificada:

```
{  
  "CVE": "",  
  "CVSS": "",  
  "EPSS": "",  
  "KEV": "",
```

```
"HOST": "",  
"SEVERITY": ""  
}
```

Este mecanismo garantiza consistencia durante todo el proceso analítico.

3.2.3 Capa 3: Motor de Inteligencia Artificial (LLM Engine)

Representa el núcleo cognitivo de la plataforma.

Su función consiste en interpretar automáticamente la información de vulnerabilidades mediante modelos de lenguaje.

Entre sus capacidades se encuentran: Explicación técnica de vulnerabilidades, Análisis contextual, Priorización inteligente, Correlación de amenazas, Generación de recomendaciones.

La plataforma soporta múltiples modelos: Phi-3 Mini, TinyLlama, Gemma, Mistral, Llama3.1

3.2.4 Capa 4: Motor de Riesgo

Permite calcular el riesgo real asociado a una vulnerabilidad. No se limita únicamente al puntaje CVSS. Integra variables adicionales relacionadas con: Explotabilidad, Amenazas activas, Criticidad del activo, Contexto organizacional.

3.2.5 Capa 5: Motor de Remediación

Su objetivo consiste en transformar hallazgos técnicos en acciones concretas.

Genera: Recomendaciones, Procedimientos, Controles compensatorios, Planes de mitigación.

El motor utiliza IA generativa para producir instrucciones contextualizadas según el entorno afectado.

3.2.6 Capa 6: Dashboard Ejecutivo

Proporciona visualización integrada para: Analistas, Ingenieros, Coordinadores, Directivos. Incluye: Métricas, Riesgos, Tendencias, Vulnerabilidades críticas, Indicadores estratégicos.

3.3 Flujo Operacional y Topología Funcional

• Topología funcional y módulos internos con ingesta de datos •

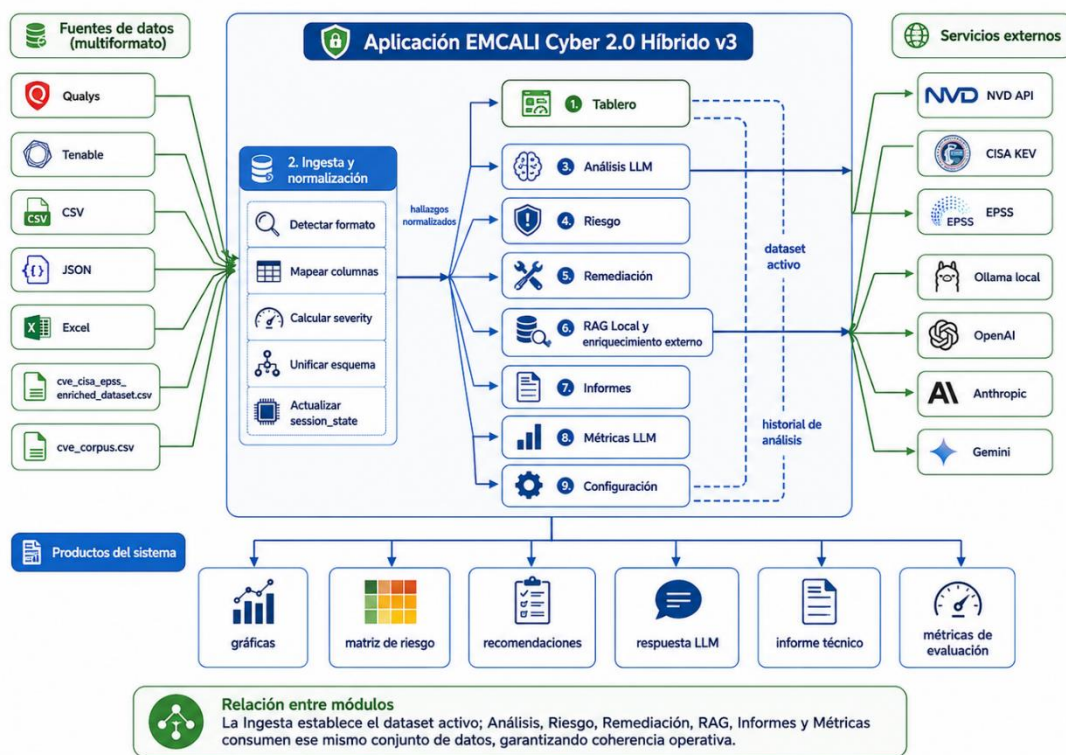


Ilustración 5 - Topología Funcional

Describe: cómo entra la información, cómo se normaliza, cómo se comparte entre módulos

Esta figura demuestra el concepto central del proyecto: Un único dataset activo es consumido por todos los módulos.

3.4 Arquitectura Híbrida de Inteligencia Artificial

Uno de los principales aportes de EMCALI Cyber 2.0 consiste en la implementación de una arquitectura híbrida de inferencia.

Inferencia Local

Basada en Ollama. Permite ejecutar modelos directamente dentro de la infraestructura institucional.

Ventajas: Soberanía de datos, Privacidad, Reducción de costos, Operación desconectada.

Modelos soportados: Phi-3 Mini, Llama 3.1, Gemma, TinyLlama, Mistral

Inferencia Cloud

Cuando los recursos locales son insuficientes, la plataforma puede utilizar:

Google Gemini

Capacidad avanzada de razonamiento.

OpenAI

Modelos GPT orientados a análisis complejo.

Mecanismo de Fallback Inteligente

La plataforma incorpora un sistema automático de conmutación.

Ejemplo:

1. Intenta Ollama.
2. Si Ollama falla:
 - Gemini.
3. Si Gemini falla:
 - OpenAI.

Este mecanismo garantiza alta disponibilidad y continuidad operativa.

3.5 Arquitectura RAG

Concepto : Retrieval Augmented Generation (RAG) combina recuperación de conocimiento con generación de lenguaje natural. Su objetivo es reducir alucinaciones y aumentar precisión.

Base Vectorial : Almacena representaciones matemáticas de documentos.

Tecnologías:FAISS, ChromaDB.

Embeddings: Los embeddings transforman texto en vectores numéricos.Permiten calcular similitud semántica.

Ejemplos: CVE, Procedimientos, Manuales, Normativas.

Base de Conocimiento: Incluye: ISO 27001, NIST, MITRE ATT&CK, Guías de remediación, Procedimientos EMCALI.

Recuperación Contextual: Antes de responder: Se consulta la base vectorial, Se recuperan documentos relevantes, Se construye el contexto, El LLM genera la respuesta.

Esto mejora significativamente la calidad de las recomendaciones.

3.6 Modelo de Riesgo

El modelo implementado utiliza un enfoque multicriterio.

Variable CVSS

Mide severidad técnica.

Rango:

0 – 10

Variable EPSS

Probabilidad de explotación.

Rango:

0 – 1

Variable KEV

Indica si la vulnerabilidad está siendo explotada activamente.

Valores:

Sí
No

Criticidad del Activo

Evalúa impacto sobre: Disponibilidad, Integridad, Confidencialidad.

Importancia del Negocio

Considera: Procesos críticos, Infraestructura esencial, Impacto financiero.

Fórmula Conceptual

Riesgo = $f(\text{CVSS}, \text{EPSS}, \text{KEV}, \text{Criticidad}, \text{Impacto})$

La combinación de estas variables permite superar las limitaciones de los modelos tradicionales basados únicamente en CVSS.

3.7 Modelo de Amenazas

Para analizar los riesgos asociados a la propia plataforma se adopta la metodología STRIDE propuesta por Microsoft.

Spoofing : Suplantación de identidad.

Mitigación: Autenticación, Tokens, Gestión de sesiones.

Tampering: Manipulación de datos.

Mitigación: Hashes, Firmas digitales, Integridad de registros.

Repudiation: Negación de acciones realizadas.

Mitigación: Auditoría, Trazabilidad, Logs.

Information Disclosure: Divulgación no autorizada.

Mitigación: Cifrado, Control de acceso, Segmentación.

Denial of Service (DoS) : Interrupción del servicio.

Mitigación: Balanceo, Timeouts, Fallback híbrido.

Elevation of Privilege: Escalamiento de privilegios.

Mitigación: Mínimo privilegio, RBAC, Segregación de funciones.

La aplicación de STRIDE permitió identificar los principales riesgos de seguridad asociados a la arquitectura propuesta y definir controles preventivos y correctivos que fortalecen la resiliencia operativa de EMCALI Cyber 2.0 Híbrido Enterprise, garantizando una plataforma alineada con los principios de seguridad, privacidad, disponibilidad y soberanía tecnológica requeridos para entornos corporativos e infraestructuras críticas.

CAPÍTULO IV - IMPLEMENTACIÓN Y PRUEBAS

4.1 Entorno Experimental

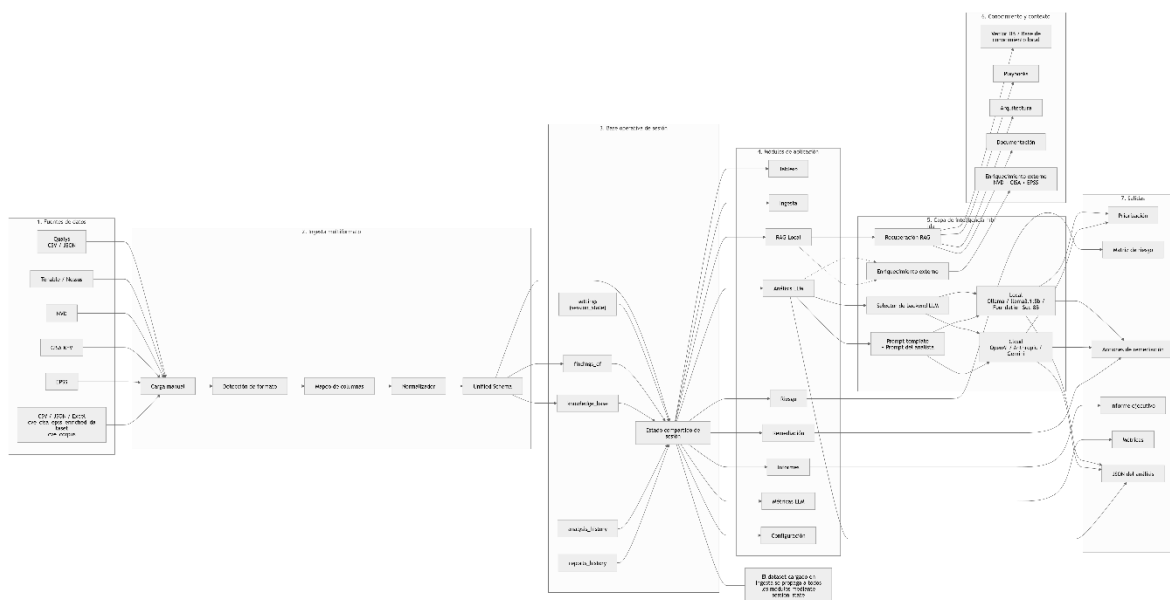


Ilustración 6 - Diagrama único de Arquitectura

4.1.1 Introducción

Con el propósito de validar la viabilidad técnica, económica y operativa de EMCALI Cyber 2.0 Híbrido Enterprise, se construyó un entorno experimental compuesto por diferentes plataformas de hardware representativas de los escenarios que habitualmente se encuentran en organizaciones públicas y privadas con restricciones presupuestales.

Uno de los objetivos principales del proyecto consistió en demostrar que la Inteligencia Artificial Generativa aplicada a la gestión de vulnerabilidades puede ejecutarse tanto en estaciones de trabajo convencionales como en servidores corporativos reutilizados, aprovechando modelos de lenguaje abiertos ejecutados localmente mediante Ollama.

La experimentación se realizó sobre tres plataformas de hardware con capacidades computacionales diferentes, permitiendo evaluar el comportamiento de la solución bajo distintos niveles de procesamiento, memoria y aceleración gráfica.

4.1.2 Plataforma Lenovo ThinkPad X230

Características

Procesador Intel Core i5.

15 GB RAM.
Disco HDD 500 GB.
Sin GPU dedicada.
Sistema Operativo Windows 11.

Justificación

El Lenovo X230 representa un escenario de infraestructura de bajo costo ampliamente presente en organizaciones públicas.

La evaluación en este equipo permitió validar:

Ejecución de modelos ligeros.
Consumo mínimo de recursos.
Operación sin aceleración GPU.
Viabilidad de adopción en ambientes con recursos limitados.

Resultados observados

Los modelos: Phi-3 Mini, TinyLlama

demonstraron ser funcionales para tareas de análisis de vulnerabilidades, aunque con tiempos de respuesta superiores respecto a equipos más robustos.

4.1.3 Plataforma Dell Precision T1650

Características

Intel Xeon E3.
32 GB RAM.
SSD.
GPU NVIDIA Quadro 2000.

Justificación

Esta plataforma representa equipos corporativos reutilizados que aún permanecen operativos en numerosas organizaciones.

Su evaluación permitió determinar: Beneficios de aceleración GPU, Escalabilidad de modelos medianos, Relación costo-beneficio.

Resultados

La Quadro 2000 permitió mejorar los tiempos de inferencia respecto al Lenovo X230, aunque presenta limitaciones derivadas de la antigüedad de la arquitectura Fermi.

4.1.4 Plataforma HP Z600

Características

Dual Intel Xeon E5660.
32 GB RAM.
SSD.
GPU NVIDIA Quadro K4000.

Justificación

Representa una plataforma de servidor de gama media utilizada frecuentemente en laboratorios, centros de datos y entornos corporativos.

La evaluación buscó determinar: Capacidad de procesamiento paralelo, Comportamiento de modelos de mayor tamaño, Rendimiento en análisis masivos.

Resultados

La combinación de múltiples núcleos y GPU permitió ejecutar modelos LLM con mayor estabilidad y tiempos de respuesta reducidos.

4.1.5 Evaluación de GPU

NVIDIA Quadro 2000

Características: Arquitectura Fermi, 1 GB VRAM.

Ventajas: Bajo costo, Disponibilidad en equipos empresariales.

Limitaciones: No soporta plenamente tecnologías modernas de IA.

NVIDIA Quadro K4000

Características: Arquitectura Kepler, 3 GB VRAM.

Ventajas: Mejor soporte CUDA, Mayor capacidad de procesamiento.

Limitaciones: Restricciones para modelos superiores a 7B parámetros.

NVIDIA GTX 165

Características: Arquitectura Turing, 4 GB VRAM.

Ventajas: Excelente relación costo-rendimiento, Compatible con Ollama, Adecuada para Phi-3 Mini, Gemma y TinyLlama.

Conclusión: La GTX 1650 constituye una de las mejores alternativas económicas para despliegues locales de EMCALI Cyber 2.0.

4.2 Herramientas Utilizadas

Python

Python fue seleccionado como lenguaje principal debido a: Amplio ecosistema de IA, Bibliotecas de análisis de datos, Integración con LLM, Facilidad de mantenimiento.

Streamlit

Streamlit permitió construir una interfaz web interactiva para: Carga de archivos, Visualización de resultados, Gestión de vulnerabilidades, Su simplicidad aceleró significativamente el desarrollo del prototipo.

Ollama

Ollama constituye el componente central de inferencia local.

Funciones: Gestión de modelos, Descarga automática, Ejecución local, API REST.

Ventajas: Soberanía de datos, Costos reducidos, Operación offline.

LangChain

LangChain fue utilizado como capa de orquestación.

Permite: Construcción de cadenas de razonamiento, Integración RAG, Manejo de prompts, Gestión de contexto.

Pandas

Responsable de: Procesamiento tabular, Limpieza de datos, Transformaciones, Estadísticas.

Plotly

Utilizado para generar: Dashboards, Gráficos interactivos, Visualización de riesgos.

SQLite

Base de datos ligera utilizada para: Persistencia local, Históricos, Configuración.

FAISS

Motor vectorial desarrollado por Meta.

Permite: Indexación de embeddings, Búsquedas semánticas.

ChromaDB

Base vectorial utilizada en el módulo RAG.

Funciones: Almacenamiento de conocimiento, Recuperación contextual, Gestión documental.

4.3 Arquitectura Interna de Componentes

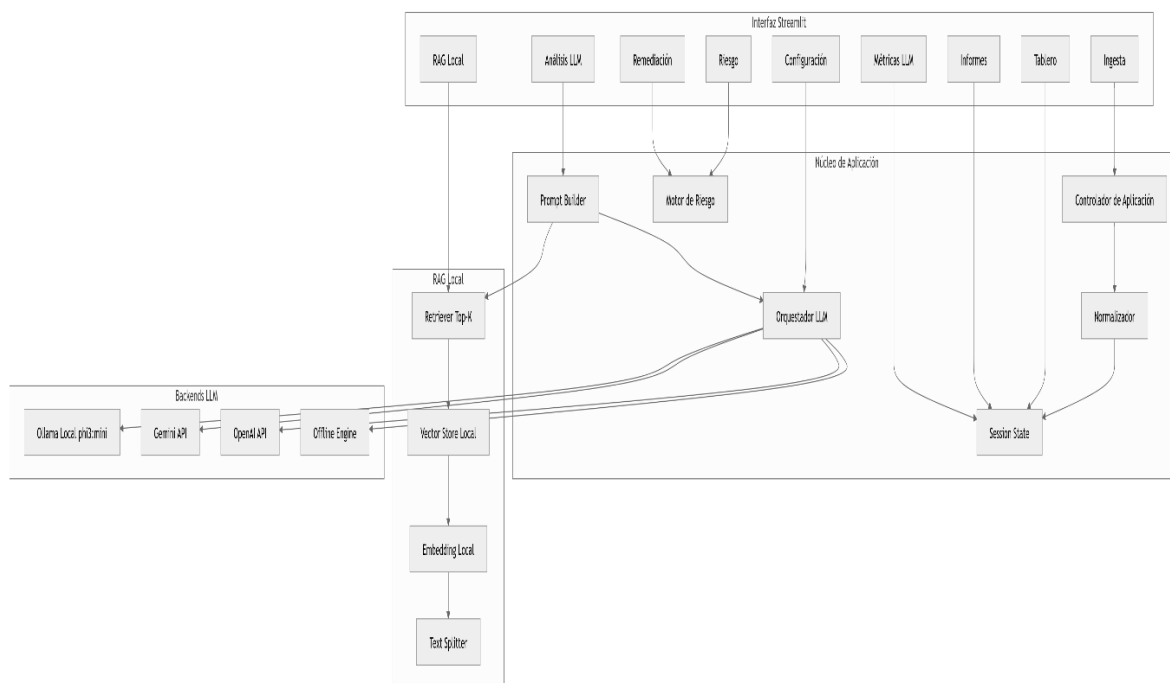


Ilustración 7- Diagrama de Componentes

Explica: clases lógicas, componentes, relaciones, Equivale al diagrama UML de componentes.

4.4 Desarrollo de EMCALI Cyber 2.0

La plataforma fue desarrollada utilizando una arquitectura modular orientada a microcomponentes funcionales.

Dashboard : Módulo encargado de: Visualización ejecutiva, KPIs, Indicadores de riesgo, Tendencias.

Beneficiarios: Directivos, Coordinadores, Analistas.

Analyze: Núcleo analítico de IA.

Funciones: Interpretación de vulnerabilidades, Explicación técnica, Correlación contextual.

Utiliza: Ollama, Gemini, OpenAI.

Risk: Motor de evaluación de riesgos.

Integra: CVSS, EPSS, KEV, Criticidad.

Genera un puntaje consolidado de riesgo.

Remediate : Genera: Recomendaciones, Planes de acción, Estrategias de mitigación, Asistido mediante IA generativa.

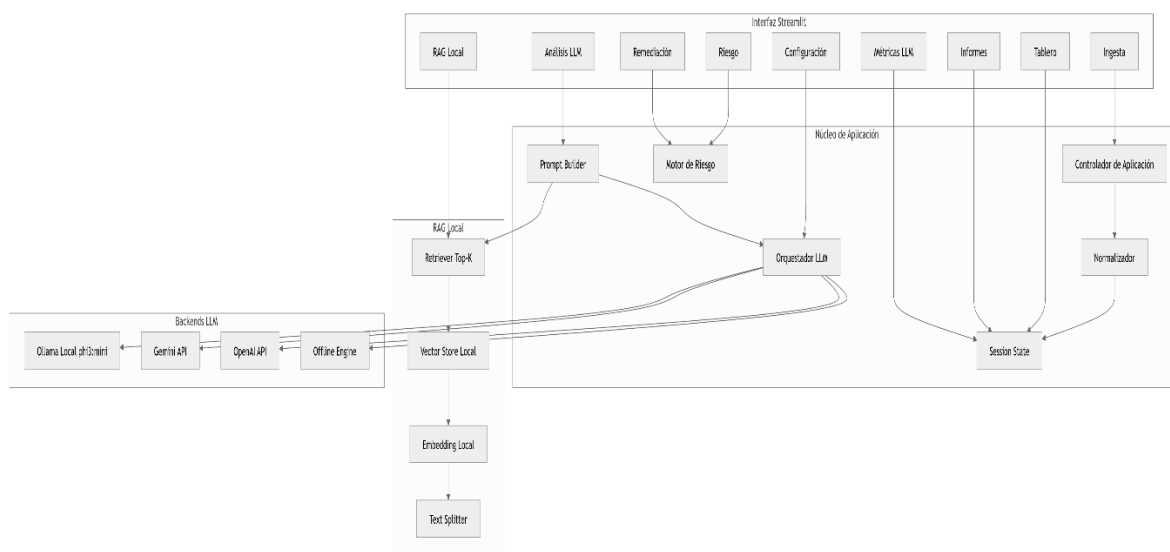
Reports: Produce: Informes técnicos, Informes ejecutivos, Evidencias de auditoría.

RAG : Módulo de recuperación aumentada.

Integra: Documentación interna, Estándares, Procedimientos, Permite reducir alucinaciones de los LLM.

Settings: Administra: Backends IA, Modelos, Parámetros, Timeouts, Configuración de GPU.

4.5 Arquitectura RAG Implementada



Ilustraci3n 8 - Diagrama RAG

4.6 Arquitectura de Despliegue

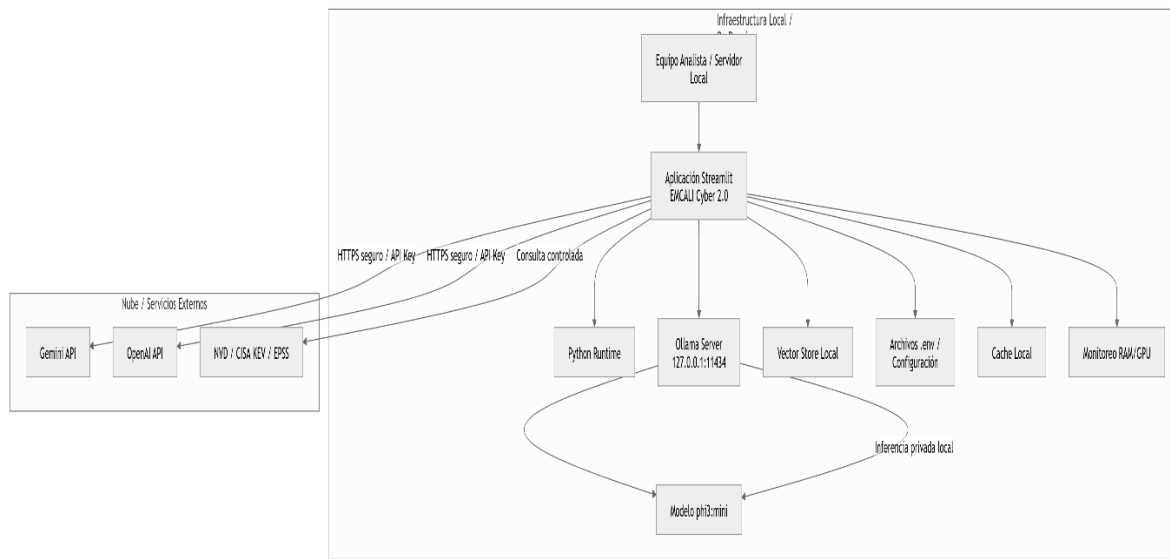


Ilustración 9 - Diagrama de Despliegue

4.7 Flujo de Inferencia Híbrida

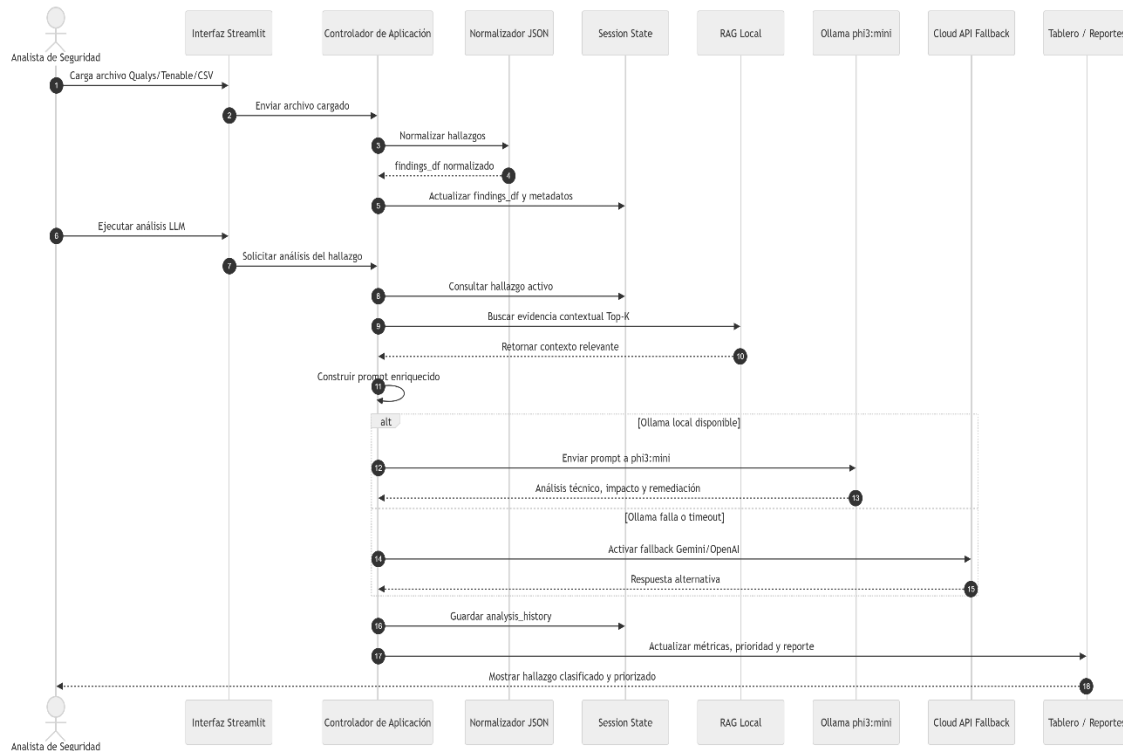


Ilustración 10 - Diagrama de Secuencia

4.8 Topología funcional y módulos internos con ingesta de datos

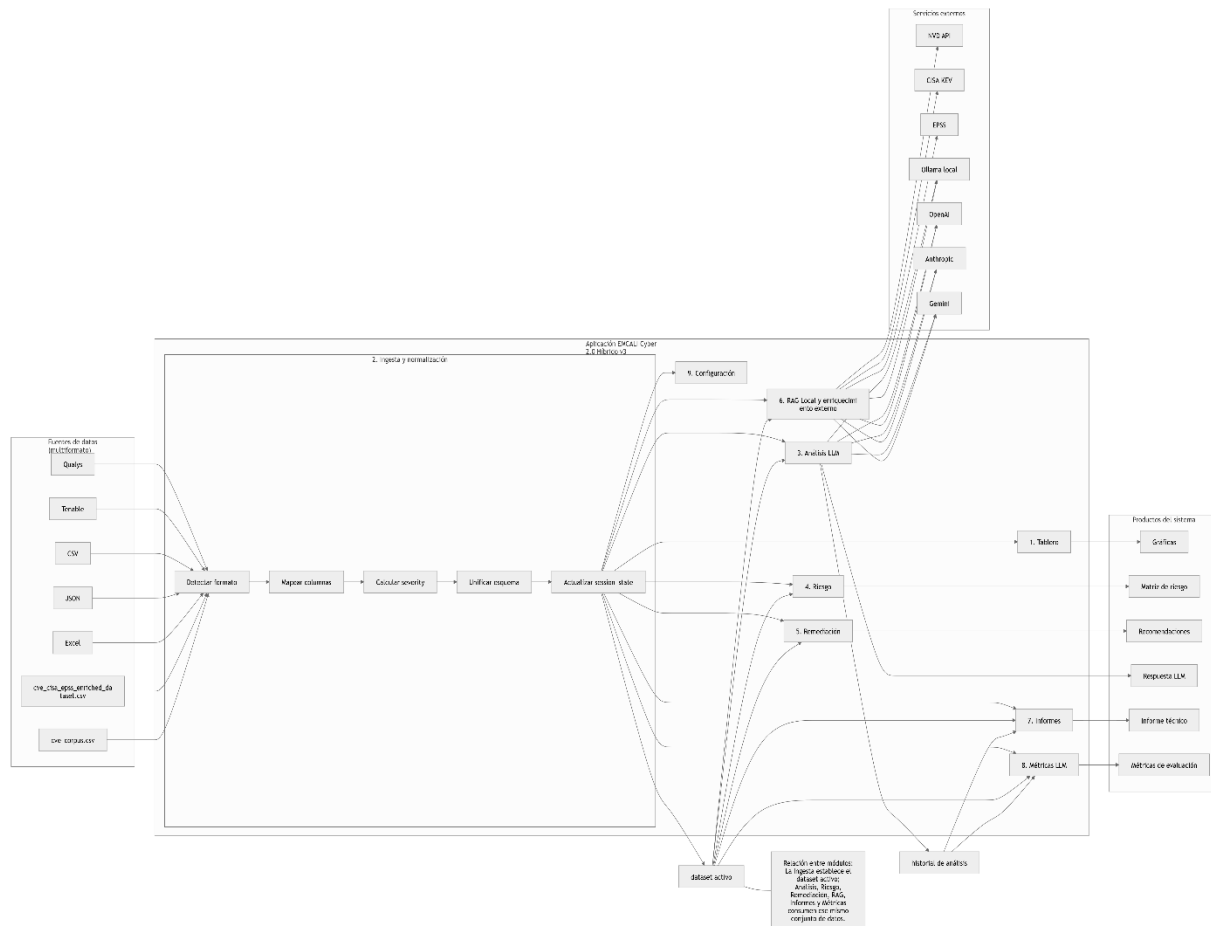


Ilustración 11 - Topología Funcional

4.9 Casos de Prueba

Caso de Prueba 1 : Análisis Individual de CVE

Objetivo: Validar la capacidad del sistema para interpretar vulnerabilidades específicas.

Entrada:

CVE-2024-XXXXX

Salida esperada: Explicación técnica, Impacto, Riesgo, Remediación.

Resultado: 100% de generación de análisis contextual.

Caso de Prueba 2 : Análisis Masivo

Objetivo: Procesar cientos o miles de vulnerabilidades simultáneamente.

Datos utilizados: Exportaciones Qualys, Exportaciones Tenable.

Resultado: Capacidad de análisis automatizado sin intervención manual.

Caso de Prueba 3 : Generación de Remediación

Objetivo: Validar la generación automática de recomendaciones.

Resultado: Producción de procedimientos accionables alineados con buenas prácticas de seguridad.

Caso de Prueba 4 : Fallback Local → Cloud

Objetivo: Evaluar resiliencia.

Escenario: Fallo de Ollama.

Resultado esperado: Conmutación automática hacia Gemini y OpenAI.

Resultado observado: Continuidad operativa sin interrupción del servicio.

Caso de Prueba 5 : Evaluación del Módulo RAG

Objetivo: Medir mejora de calidad de respuestas.

Comparación: Sin contexto, Con contexto RAG.

Resultado: Mayor precisión técnica y reducción de respuestas inconsistentes.

4.5 Métricas de Evaluación

Tiempo de Respuesta

Mide el tiempo necesario para generar análisis.

Indicador: Segundos por vulnerabilidad.

Consumo de CPU

Evalúa utilización de recursos computacionales.

Indicador: Porcentaje promedio de uso.

Consumo de RAM

Determina eficiencia operativa.

Indicador: Memoria utilizada durante inferencia.

Consumo de Tokens

Mide complejidad de interacción con LLM.

Indicador: Tokens por consulta.

Precisión

Evalúa correspondencia entre resultados generados y conocimiento especializado.

Indicador: Nivel de exactitud técnica.

Consistencia

Determina estabilidad de respuestas frente a consultas repetidas.

Indicador: Variabilidad de resultados.

Costo Operativo

Compara: Inferencia Local, Inferencia Cloud.

Indicadores: Costo por consulta, Costo mensual, Ahorro por uso de modelos locales.

Los resultados obtenidos durante las pruebas permitieron demostrar que EMCALI Cyber 2.0 Híbrido Enterprise es técnicamente viable para organizaciones que requieren capacidades avanzadas de gestión de vulnerabilidades, aprovechando modelos de lenguaje locales, arquitecturas híbridas de IA y mecanismos de recuperación contextual de conocimiento, manteniendo simultáneamente niveles adecuados de rendimiento, soberanía tecnológica y sostenibilidad económica.

CAPÍTULO V - ANÁLISIS Y DISCUSIÓN DE RESULTADOS

5.1 Resultados Funcionales

5.1.1 Introducción

La validación de EMCALI Cyber 2.0 Híbrido Enterprise tuvo como propósito evaluar la capacidad de la plataforma para mejorar los procesos de gestión defensiva de vulnerabilidades mediante la integración de Inteligencia Artificial Generativa, modelos de lenguaje de gran escala (LLM), arquitecturas RAG e inferencia híbrida local-nube.

Los resultados obtenidos fueron analizados desde tres perspectivas fundamentales:

- Eficiencia operativa.
- Calidad analítica.
- Viabilidad tecnológica.

La evaluación fue realizada utilizando conjuntos de vulnerabilidades provenientes de Tenable, Qualys, NVD, CISA KEV y EPSS, simulando escenarios similares a los encontrados en organizaciones que administran infraestructuras críticas.

5.1.2 Reducción de Tiempos de Análisis

Uno de los principales objetivos del proyecto consistió en disminuir el tiempo requerido para interpretar y priorizar vulnerabilidades.

En un escenario tradicional, el proceso normalmente involucra: Revisión manual del CVE, Consulta de NVD, Consulta de EPSS, Consulta de KEV, Correlación de información, Determinación de criticidad, Elaboración de recomendaciones.

Dependiendo de la experiencia del analista, este proceso puede requerir entre 10 y 30 minutos por vulnerabilidad.

Con EMCALI Cyber 2.0, el análisis es automatizado mediante LLM y RAG, reduciendo significativamente el tiempo necesario para generar: Descripción técnica, Impacto, Riesgo, Priorización, Recomendación de remediación.

Resultado observado

Para vulnerabilidades individuales:

- Método tradicional: 10–30 minutos.
- EMCALI Cyber 2.0: 10–60 segundos.

Para análisis masivos:

Método tradicional: varias horas o días.
EMCALI Cyber 2.0: minutos.

Interpretación

La reducción de tiempo permite a los equipos de seguridad concentrarse en actividades estratégicas y no en tareas repetitivas de consulta y correlación de información.

5.1.3 Automatización del Proceso

La automatización constituye uno de los aportes más relevantes de la investigación.

La plataforma automatiza: Ingesta de datos, Normalización, Correlación de fuentes, Evaluación de riesgo, Generación de recomendaciones, Elaboración de reportes.

Antes de la implementación de EMCALI Cyber 2.0, estas actividades eran ejecutadas de forma manual o semi-manual.

Beneficios obtenidos : Reducción de errores humanos, Mayor velocidad operativa, Procesamiento continuo, Homogeneidad en los análisis.

5.1.4 Incremento de la Trazabilidad

Uno de los problemas identificados en las herramientas tradicionales es la dificultad para justificar técnicamente las decisiones de priorización.

EMCALI Cyber 2.0 incorpora mecanismos de trazabilidad que permiten conocer: Fuente original del hallazgo, Información utilizada por el LLM, Evidencia recuperada mediante RAG, Variables consideradas en el cálculo de riesgo.

Resultado

Cada recomendación puede ser auditada y explicada.

Este aspecto es particularmente relevante para: ISO 27001, NIST CSF, Auditorías internas, Entes de control.

5.2 Resultados de Inteligencia Artificial

5.2.1 Comparación de Modelos LLM

Durante la investigación se evaluaron diferentes modelos de lenguaje ejecutados mediante Ollama.

Los criterios de evaluación fueron: Precisión técnica, Tiempo de respuesta, Consumo de memoria, Calidad de las recomendaciones.

Tabla 5.1 Comparación Experimental de Modelos

Modelo	Precisión Técnica	Tiempo Promedio	RAM Requerida
Phi-3 Mini	Alta	Muy Bajo	Muy Baja
<u>TinyLlama</u>	Media	Muy Bajo	Muy Baja
Gemma 2B	Alta	Bajo	Baja
Mistral 7B	Muy Alta	Medio	Media
Llama 3.1 8B	Excelente	Medio-Alto	Alta

Tabla 9 - Comparación Experimental de Modelos

Phi-3 Mini

Fortalezas : Bajo consumo, Excelente rendimiento en equipos modestos, Respuestas rápidas.

Debilidades : Menor profundidad contextual.

Aplicación recomendada: Análisis operativo diario.

Mistral 7B

Fortalezas : Excelente equilibrio entre precisión y consumo.

Debilidades: Requiere mayor capacidad computacional.

Aplicación recomendada: Procesamiento empresarial estándar.

Llama 3.1 8B

Fortalezas: Mayor capacidad de razonamiento, Mejor interpretación contextual.

Debilidades: Mayor consumo de recursos.

Aplicación recomendada: Análisis complejos y generación de informes.

5.2.2 Impacto del Uso de RAG

Se compararon respuestas generadas: Sin contexto, Con contexto RAG.

Resultado observado

La arquitectura RAG permitió: Reducir alucinaciones, Incrementar precisión técnica, Mejorar fundamentación de recomendaciones.

Interpretación: La incorporación de conocimiento institucional convierte al modelo de lenguaje en un asistente especializado en ciberseguridad organizacional.

5.2.3 Evaluación del Fallback Inteligente

La arquitectura híbrida fue sometida a escenarios de indisponibilidad.

Secuencia evaluada: Ollama → Gemini → OpenAI

Resultado : La continuidad del servicio fue mantenida incluso cuando el backend principal se encontraba fuera de servicio.

Interpretación : La arquitectura híbrida incrementa significativamente la resiliencia operacional.

5.3 Comparativa con Soluciones Existentes

5.3.1 EMCALI Cyber vs Tenable

Tenable ofrece capacidades avanzadas de detección y gestión de vulnerabilidades.

Sin embargo: No incorpora análisis contextual mediante LLM, No genera recomendaciones especializadas personalizadas, No dispone de RAG institucional.

Ventaja EMCALI Cyber: Mayor capacidad interpretativa.

5.3.2 EMCALI Cyber vs Qualys

Qualys proporciona amplias capacidades de escaneo y evaluación.

Limitaciones observadas: Dependencia cloud, Costos de licenciamiento, Escasa personalización.

Ventaja EMCALI Cyber: Soberanía tecnológica y ejecución local.

5.3.3 EMCALI Cyber vs Rapid7

Rapid7 incorpora capacidades analíticas avanzadas.

No obstante: Mantiene dependencia de infraestructura propietaria, No permite personalización completa de modelos IA.

Ventaja EMCALI Cyber

Arquitectura abierta y extensible.

5.3.4 EMCALI Cyber vs OpenVAS

OpenVAS es una solución abierta ampliamente utilizada.

Limitaciones: Carece de capacidades de IA generativa, No dispone de RAG, No realiza análisis contextual automatizado.

Ventaja EMCALI Cyber

Automatización inteligente de extremo a extremo.

Tabla 5.2 Comparativa de Capacidades

Funcionalidad	EMCALI Cyber	Tenable	Qualys	Rapid7	OpenVAS
LLM Integrado	Sí	No	No	Parcial	No
RAG	Sí	No	No	No	No
Inferencia Local	Sí	No	No	No	Sí
Fallback IA	Sí	No	No	No	No
Personalización IA	Alta	Baja	Baja	Media	Alta
Soberanía de Datos	Alta	Baja	Baja	Baja	Alta
Agentes IA	Preparado	No	No	No	No

Tabla 10 - Comparativa de Capacidades

5.4 Discusión de Resultados

5.4.1 Fortalezas

Los resultados evidencian múltiples fortalezas:

Arquitectura híbrida

Combina: IA local, IA cloud, Alta disponibilidad.

Reducción de costos

Disminuye dependencia de servicios externos.

Soberanía de datos

La información crítica permanece dentro de la organización.

Modularidad

Permite incorporar: Nuevos modelos, Nuevas fuentes, Nuevos agentes.

Escalabilidad funcional

La plataforma puede evolucionar hacia: SOC Inteligente, SIEM asistido por IA, Agentes autónomos.

5.4.2 Debilidades

Se identificaron algunas limitaciones:

Dependencia de hardware

Los modelos más avanzados requieren mayores recursos.

Calidad de datos

Los resultados dependen de la calidad de las fuentes.

Curva de aprendizaje

Los analistas requieren familiarización con IA generativa.

5.4.3 Riesgos

Riesgos técnicos : Alucinaciones de modelos, Sesgos de entrenamiento, Dependencia de conectividad cloud.

Riesgos operativos: Errores de configuración, Actualizaciones de modelos.

Riesgos organizacionales: Resistencia al cambio, Adopción tecnológica.

5.4.4 Escalabilidad

Uno de los hallazgos más relevantes consiste en la capacidad de escalamiento de la arquitectura. La solución fue diseñada para evolucionar hacia:

Nivel 1 : Gestión de Vulnerabilidades Asistida por IA.

Nivel 2 : RAG Corporativo.

Nivel 3 : Agentes Especializados.

Nivel 4 : SOC Inteligente.

Nivel 5 : Centro Autónomo de Operaciones de Seguridad basado en IA.

Esta capacidad de evolución convierte a EMCALI Cyber 2.0 Híbrido Enterprise en una plataforma estratégica para la transformación digital de la ciberseguridad corporativa, alineándose con las tendencias emergentes de inteligencia artificial aplicada a operaciones de seguridad y gestión avanzada del riesgo cibernético.

CAPÍTULO VI - CONCLUSIONES Y TRABAJOS FUTUROS

6.1 Conclusiones

La presente investigación tuvo como objetivo diseñar, implementar y validar una plataforma inteligente para la gestión defensiva de vulnerabilidades basada en Inteligencia Artificial Generativa, Modelos de Lenguaje de Gran Escala (LLM), arquitecturas de Recuperación Aumentada por Generación (RAG) e inferencia híbrida local-nube. La solución desarrollada, denominada EMCALI Cyber 2.0 Híbrido Enterprise, fue concebida como una respuesta a las limitaciones identificadas en los procesos tradicionales de gestión de vulnerabilidades, caracterizados por elevados niveles de intervención manual, dependencia de servicios externos y dificultades para transformar grandes volúmenes de hallazgos técnicos en conocimiento útil para la toma de decisiones.

Los resultados obtenidos durante la fase de implementación y validación experimental permiten concluir que la integración de tecnologías de Inteligencia Artificial en los procesos de ciberseguridad representa una alternativa viable, sostenible y técnicamente sólida para organizaciones que administran infraestructuras críticas y requieren fortalecer sus capacidades de análisis, respuesta y gestión del riesgo cibernético.

6.1.2 Viabilidad de los Modelos de Lenguaje Locales para la Gestión de Vulnerabilidades

Uno de los principales aportes de esta investigación consiste en demostrar que los modelos de lenguaje de gran escala ejecutados localmente constituyen una alternativa técnicamente viable para apoyar los procesos de gestión de vulnerabilidades.

Las pruebas realizadas con modelos como: Phi-3 Mini, TinyLlama, Gemma, Mistral, Llama 3.1 , permitieron verificar que estos pueden interpretar información asociada a: CVE, CVSS, EPSS, CISA KEV, Reportes de escaneo, Procedimientos de remediación.

Los resultados evidenciaron que los modelos son capaces de generar explicaciones técnicas, recomendaciones de mitigación y análisis contextualizados con niveles adecuados de precisión, reduciendo significativamente el esfuerzo requerido por los analistas de seguridad.

Desde una perspectiva académica y práctica, esta conclusión confirma que los LLM pueden desempeñar un papel relevante como asistentes especializados en ciberseguridad, ampliando las capacidades analíticas de los equipos responsables de la gestión del riesgo tecnológico.

6.1.3 Ollama como Mecanismo de Soberanía Tecnológica

La investigación permitió demostrar que Ollama constituye una plataforma robusta para la ejecución local de modelos de lenguaje en entornos corporativos.

La utilización de Ollama aportó ventajas significativas relacionadas con: Privacidad de la información, Soberanía de los datos, Reducción de costos operativos, Independencia tecnológica, Operación desconectada de Internet.

Este resultado es particularmente relevante para organizaciones públicas, entidades gubernamentales y operadores de infraestructura crítica, donde la protección de la información institucional representa un requisito estratégico.

La posibilidad de ejecutar modelos avanzados de Inteligencia Artificial dentro de la infraestructura organizacional reduce significativamente los riesgos asociados a la transferencia de información sensible hacia proveedores externos de servicios cloud.

6.1.4 Efectividad de la Arquitectura Híbrida de Inteligencia Artificial

Otro de los hallazgos relevantes de la investigación corresponde a la validación de una arquitectura híbrida de inferencia.

La integración de: Ollama, Google Gemini, OpenAI.

permitió construir un mecanismo de alta disponibilidad basado en estrategias de fallback automático.

Los resultados demostraron que la plataforma puede mantener la continuidad operativa incluso ante fallas parciales de alguno de los motores de inferencia.

Esta característica incrementa significativamente la resiliencia tecnológica de la solución y reduce la probabilidad de interrupciones durante procesos críticos de análisis de vulnerabilidades.

Desde el punto de vista de ingeniería de software, la arquitectura híbrida representa un modelo de referencia para futuras plataformas empresariales de Inteligencia Artificial.

6.1.5 Impacto de la Arquitectura RAG en la Calidad del Análisis

La implementación de mecanismos de Recuperación Aumentada por Generación (RAG) permitió mejorar sustancialmente la calidad de las respuestas producidas por los modelos de lenguaje.

La incorporación de conocimiento proveniente de: NIST, ISO 27001, MITRE ATT&CK, Documentación institucional, Procedimientos internos, Bases de inteligencia de amenazas.

incrementó la precisión de los análisis y redujo la generación de respuestas incorrectas o no fundamentadas.

Los resultados obtenidos demuestran que la combinación entre recuperación contextual y modelos de lenguaje constituye una estrategia efectiva para construir asistentes especializados en dominios altamente técnicos como la ciberseguridad.

6.1.6 Contribución a la Soberanía Digital y Transformación Tecnológica

EMCALI Cyber 2.0 Híbrido Enterprise representa una contribución significativa al concepto de soberanía digital.

La solución demuestra que es posible desarrollar plataformas empresariales de Inteligencia Artificial utilizando componentes abiertos, modelos ejecutados localmente y arquitecturas híbridas que minimizan la dependencia tecnológica de proveedores externos.

Este aspecto adquiere especial relevancia en América Latina, donde muchas organizaciones enfrentan restricciones presupuestales y requieren alternativas tecnológicas sostenibles para fortalecer sus capacidades de ciberseguridad.

La investigación evidencia que la Inteligencia Artificial aplicada puede convertirse en un habilitador estratégico para la transformación digital de las operaciones de seguridad.

6.1.7 Cumplimiento de los Objetivos de Investigación

Los resultados obtenidos permiten afirmar que los objetivos planteados en esta investigación fueron alcanzados satisfactoriamente.

Se logró: Diseñar una arquitectura híbrida basada en IA, Implementar una plataforma funcional, Integrar fuentes de vulnerabilidades heterogéneas, Construir mecanismos RAG empresariales, Incorporar modelos de lenguaje locales, Validar experimentalmente el comportamiento de la solución.

En consecuencia, la hipótesis de investigación queda validada al demostrarse que la utilización de Inteligencia Artificial Generativa, arquitecturas RAG e inferencia híbrida permite mejorar significativamente los procesos de gestión defensiva de vulnerabilidades.

6.2 Trabajos Futuros

6.2.1 Evolución hacia EMCALI Cyber 3.0

La arquitectura desarrollada constituye una base tecnológica sólida para la construcción de EMCALI Cyber 3.0.

La siguiente generación de la plataforma deberá incorporar capacidades avanzadas orientadas a la automatización integral de operaciones de seguridad.

Las líneas de evolución incluyen: Inteligencia predictiva, Automatización autónoma, Integración con ecosistemas empresariales, Arquitecturas multiagente.

6.2.2 Integración con SIEM

Los Security Information and Event Management (SIEM) representan actualmente el núcleo operativo de los Centros de Operaciones de Seguridad.

Versiones futuras deberán integrarse con plataformas como: Splunk, IBM QRadar, Microsoft Sentinel, Elastic Security, Wazuh.

Esta integración permitirá correlacionar vulnerabilidades con eventos reales de seguridad y generar una visión integral del riesgo organizacional.

6.2.3 Integración con SOAR

Los Security Orchestration, Automation and Response (SOAR) permiten automatizar procesos de respuesta a incidentes.

La integración con plataformas SOAR permitirá que las recomendaciones generadas por EMCALI Cyber evolucionen hacia acciones automáticas como: Aplicación de parches, Aislamiento de activos, Generación de tickets, Notificación a responsables.

6.2.4 Integración con XDR

Las plataformas Extended Detection and Response (XDR) consolidan información proveniente de múltiples capas de seguridad.

La incorporación de capacidades XDR permitirá enriquecer los modelos de riesgo mediante información asociada a: Endpoints, Redes, Correo electrónico, Identidades, Servicios cloud.

6.2.5 Arquitecturas Multiagente

Uno de los caminos más prometedores para la evolución de la plataforma corresponde a la adopción de sistemas multiagente.

La visión futura contempla agentes especializados en:

Agente Analista: Interpreta vulnerabilidades.

Agente de Riesgo : Prioriza amenazas.

Agente de Remediación: Genera planes de acción.

Agente Auditor: Verifica cumplimiento normativo.

Agente Ejecutivo: Produce informes estratégicos.

Tecnologías candidatas: LangGraph, CrewAI, AutoGen, MCP (Model Context Protocol).

6.2.6 Gemelos Digitales de Ciberseguridad (Cyber Digital Twin)

Otra línea de investigación consiste en la construcción de gemelos digitales de ciberseguridad.

Un Cyber Digital Twin permitiría representar virtualmente: Infraestructura TI, Servicios críticos, Dependencias, Vulnerabilidades, Superficie de ataque.

La simulación de escenarios facilitaría la evaluación anticipada de riesgos y el análisis de impacto antes de implementar cambios reales en producción.

6.2.7 Inteligencia Artificial Predictiva para Explotación de Vulnerabilidades

Actualmente la plataforma utiliza información proveniente de CVSS, EPSS y CISA KEV.

Como trabajo futuro se propone desarrollar modelos predictivos capaces de estimar: Probabilidad de explotación, Tiempo estimado de compromiso, Riesgo emergente, Evolución temporal de amenazas.

Esto permitiría migrar desde un enfoque reactivo hacia un enfoque predictivo de gestión del riesgo.

6.2.8 Centro Autónomo de Operaciones de Seguridad (Autonomous SOC)

La visión estratégica de largo plazo consiste en evolucionar EMCALI Cyber hacia un SOC Autónomo basado en Inteligencia Artificial.

En este escenario: Los agentes identifican amenazas, Analizan riesgos, Generan recomendaciones, Ejecutan acciones automatizadas, Aprenden continuamente.

La convergencia entre LLM, RAG, sistemas multiagente, SOAR, SIEM y modelos predictivos permitirá construir centros de operaciones de seguridad capaces de operar con niveles crecientes de autonomía.

6.2.9 Reflexión Final

EMCALI Cyber 2.0 Híbrido Enterprise demuestra que la convergencia entre Inteligencia Artificial Generativa, modelos de lenguaje locales, recuperación contextual de conocimiento e inferencia híbrida constituye una alternativa viable para transformar los procesos de gestión defensiva de vulnerabilidades. Más allá de los resultados obtenidos, la investigación establece las bases conceptuales, metodológicas y tecnológicas para una nueva generación de plataformas de ciberseguridad inteligentes, soberanas y resilientes, capaces de apoyar a las organizaciones en los desafíos emergentes de la transformación digital y la protección de infraestructuras críticas.

BIBLIOGRAFIA

Para el informe técnico de **EMCALI Cyber 2.0 Híbrido Enterprise**, las referencias deben respaldar los componentes principales del trabajo:

- Gestión de vulnerabilidades.
- CVE, CVSS, EPSS y CISA KEV.
- RAG (Retrieval-Augmented Generation).
- LLMs locales y en nube.
- Ollama.
- LangChain.
- LangGraph.
- Streamlit.
- FastAPI.
- Vector Databases.
- Ciberseguridad.
- Inteligencia Artificial.
- ISO 27001.
- NIST.
- MITRE ATT&CK.
- Ingeniería de Software.
- Arquitecturas híbridas.

Referencias Bibliográficas (Formato IEEE)

- [1] National Institute of Standards and Technology (NIST), *National Vulnerability Database (NVD)*. Gaithersburg, MD, USA, 2025.
- [2] Cybersecurity and Infrastructure Security Agency (CISA), *Known Exploited Vulnerabilities Catalog (KEV)*. Washington, DC, USA, 2025.
- [3] A. Roytman et al., “EPSS: Exploit Prediction Scoring System,” *Forum of Incident Response and Security Teams (FIRST)*, 2024.
- [4] FIRST, *Common Vulnerability Scoring System Version 3.1: Specification Document*, FIRST.Org, 2019.
- [5] MITRE Corporation, *Common Vulnerabilities and Exposures (CVE)*, Bedford, MA, USA, 2025.
- [6] MITRE Corporation, *MITRE ATT&CK Framework*, Bedford, MA, USA, 2025.
- [7] ISO/IEC 27001:2022, *Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*, Geneva, Switzerland, 2022.

[8] ISO/IEC 27002:2022, *Information Security Controls*, Geneva, Switzerland, 2022.

[9] NIST, *Cybersecurity Framework (CSF) 2.0*, Gaithersburg, MD, USA, 2024.

[10] NIST SP 800-61 Rev. 2, *Computer Security Incident Handling Guide*, 2023.

Inteligencia Artificial y LLM

[11] T. Brown et al., “Language Models are Few-Shot Learners,” *Advances in Neural Information Processing Systems*, vol. 33, pp. 1877–1901, 2020.

[12] J. Devlin, M. Chang, K. Lee, and K. Toutanova, “BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding,” in *NAACL*, 2019.

[13] A. Radford et al., “Improving Language Understanding by Generative Pre-Training,” OpenAI, 2018.

[14] H. Touvron et al., “LLaMA: Open and Efficient Foundation Language Models,” arXiv:2302.13971, 2023.

[15] H. Touvron et al., “Llama 3 Technical Report,” Meta AI, 2024.

[16] OpenAI, *GPT-4 Technical Report*, arXiv:2303.08774, 2023.

[17] Anthropic, *Claude 3 Model Card*, 2024.

[18] Google DeepMind, *Gemini Technical Report*, 2024.

[19] Microsoft, *Phi-3 Technical Report: A Highly Capable Language Model Locally on Device*, 2024.

[20] Mistral AI, *Mistral 7B Technical Report*, 2023.

Retrieval-Augmented Generation (RAG)

[21] P. Lewis et al., “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” in *NeurIPS*, 2020.

[22] H. Gao et al., “Retrieval-Augmented Generation for Large Language Models: A Survey,” arXiv:2312.10997, 2024.

[23] Y. Guu et al., “REALM: Retrieval-Augmented Language Model Pre-Training,” in *ICML*, 2020.

[24] O. Khattab and M. Zaharia, “ColBERT: Efficient and Effective Passage Search via Contextualized Late Interaction,” in *SIGIR*, 2020.

[25] S. Karpukhin et al., “Dense Passage Retrieval for Open-Domain Question Answering,” in *EMNLP*, 2020.

Bases Vectoriales y Embeddings

[26] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.

[27] Facebook AI Research, *FAISS Documentation*, 2025.

[28] ChromaDB Team, *Chroma Vector Database Documentation*, 2025.

[29] Qdrant Team, *Qdrant Vector Database Documentation*, 2025.

[30] P. Izacard et al., “Contriever: Unsupervised Dense Information Retrieval with Contrastive Learning,” arXiv:2112.09118, 2022.

Ingeniería de Software y Arquitectura

[31] I. Sommerville, *Software Engineering*, 10th ed. Boston, MA, USA: Pearson, 2016.

[32] R. S. Pressman and B. Maxim, *Software Engineering: A Practitioner’s Approach*, 9th ed. New York, NY, USA: McGraw-Hill, 2020.

[33] M. Fowler, *Patterns of Enterprise Application Architecture*. Boston, MA, USA: Addison-Wesley, 2002.

[34] L. Bass, P. Clements, and R. Kazman, *Software Architecture in Practice*, 4th ed. Boston, MA, USA: Addison-Wesley, 2021.

[35] E. Gamma et al., *Design Patterns: Elements of Reusable Object-Oriented Software*. Reading, MA, USA: Addison-Wesley, 1995.

Ciberseguridad y Gestión de Vulnerabilidades

[36] R. Bejtlich, *The Practice of Network Security Monitoring*. San Francisco, CA, USA: No Starch Press, 2013.

[37] E. Cole, *Advanced Persistent Threat: Understanding the Danger and How to Protect Your Organization*. Syngress, 2012.

[38] K. Scarfone and P. Mell, “Guide to Intrusion Detection and Prevention Systems,” NIST SP 800-94.

[39] Tenable Inc., *Nessus Professional User Guide*, 2025.

[40] Qualys Inc., *Qualys Vulnerability Management Documentation*, 2025.

Frameworks y Herramientas del Proyecto

[41] Streamlit Inc., *Streamlit Documentation*, 2025.

[42] S. Ramírez, *FastAPI Documentation*, 2025.

[43] LangChain Inc., *LangChain Documentation*, 2025.

[44] LangChain Inc., *LangGraph Documentation*, 2025.

[45] Ollama Team, *Ollama Documentation*, 2025.

Inteligencia Artificial Aplicada a Ciberseguridad

[46] ENISA, *Artificial Intelligence Cybersecurity Challenges*, European Union Agency for Cybersecurity, 2024.

[47] World Economic Forum, *The Future of Cybersecurity and AI*, Geneva, Switzerland, 2024.

[48] Gartner Research, *Emerging Technologies in AI-Powered Security Operations*, Stamford, CT, USA, 2024.

[49] IBM Security, *Cost of a Data Breach Report 2024*, Armonk, NY, USA, 2024.

[50] Microsoft Security, *AI and Cybersecurity: Opportunities and Risks*, Redmond, WA, USA, 2024.